

1

FIRST:

1

SECOND:

1

THIRD:

2

FOURTH:

2

FIFTH:

5

SIXTH:

5

SEVENTH:

5

EIGHTH:

5

NINTH:

5

Preliminary: Reiteration of previously presented allegations.

5

First: Existence of criminal prejudiciality.

6

Second: On the factual assumption.

6

Third: On the victim role of ORANGE. On the Modus Operandi.

8

Fourth: On the non-existence of lack of standing in the processing of personal data of ORANGE.

9

Fifth: On the correct implementation of privacy by design and by default.

12

Sixth: Accumulation of infringements.

15

Seventh: On the inadmissibility of objective liability.

.....
16

Eighth: Regarding the measures adopted and implemented by ORANGE.

.....
18

Ninth: Lack of proportionality of the imposed sanction.

.....
20

TENTH:

.....
23

ELEVENTH:

.....
23

TWELFTH:

.....
23

First.- On the existence of criminal prejudiciality.

.....
23

Second. On the factual assumption.

.....
24

Third. On the criminal conduct of the agents.

.....
26

Fourth. On the non-existence of lack of standing in the processing of personal data of ORANGE.

.....
28

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/120

Fifth. On the correct implementation of privacy by design and by default.

.....
29

Sixth. On the existence of a concurrence of infringements.

.....
33

Seventh. On the inadmissibility of objective liability.

.....
33

Eighth. On the measures adopted and implemented by ORANGE.

.....
34

PROVEN FACTS

.....
37

FIRST:

.....
38
SECOND:

.....
39
THIRD:

.....
39
FOURTH

.....
39
FIFTH:

.....
40
SIXTH:

.....
40
SEVENTH:

.....
40
EIGHTH:

.....
41
NINTH:

.....
41
TENTH:

.....
42
ELEVENTH:

.....
42
TWELFTH:

.....
42
THIRTEENTH:

.....
47
FOURTEENTH:

.....
51
LEGAL GROUNDS

.....
56
I Jurisdiction

.....

56

II Preliminary issues

56

III Response to the allegations regarding the initiation agreement

57

First: Existence of criminal prejudiciality.

57

Second: On the factual assumption.

59

Third: On the victim role of ORANGE. On the Modus Operandi.

64

Fourth: On the non-existence of lack of standing in the processing of personal data of ORANGE.

68

Fifth: On the correct implementation of privacy by design and by default.

70

Sixth: Accumulation of infringements.

76

Seventh: On the inadmissibility of objective liability.

84

Eighth: Regarding the measures adopted and implemented by
ORANGE

.

88

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

3/120

Ninth: Lack of proportionality of the imposed sanction.

88

IV Response to the allegations regarding the proposed resolution of the sanctioning procedure

.....

96

First. On the existence of criminal prejudiciality.

.....

96

Second. On the factual assumption.

.....

98

Third. On the criminal conduct of the agents.

.....

103

Fourth. On the non-existence of lack of standing in the processing of personal data by ORANGE.

.....

104

Fifth. On the correct implementation of privacy by design and by default.

.....

105

Sixth. On the existence of an accumulation of infringements.

.....

109

Seventh. On the inadmissibility of objective liability.

.....

110

Eighth. On the measures adopted and implemented by ORANGE.

.....

112

9. On the lack of proportionality of the proposed sanction.

.....

115

V Unfulfilled obligation

.....
117

VI

Classification and qualification of the infringement

.....
119

VII Sanction for the infringement of Article 6.1 of the GDPR

.....
119

VIII

Data protection by design and by default

.....
120

IX Classification of the infringement of Article 25

.....
126

X Sanction for the infringement of Article 25 of the GDPR

.....
126

XI Adoption of measures

.....
128

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/120

File No.: EXP202213023

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on November 23, 2022. The complaint is directed against ORANGE ESPAGNE, S.A.U. with NIF A82009812 (hereinafter, ORANGE). The reasons for the complaint are as follows:

The claimant states that a duplicate of their SIM card was issued without properly verifying their identity and without their ID, impersonating their identity. The duplicate was issued at a store of the entity on November 15, 2022.

The claimant indicates that as a result of the duplicate, money was withdrawn from their bank accounts amounting to 9,000 euros.

Relevant documentation provided by the claimant:

- Official complaint form from the Community of Madrid.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to ORANGE for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on December 29, 2022, as evidenced by the acknowledgment of receipt in the file.

On January 31, 2023, this Agency received a response indicating the following:

"Having confirmed the irregularity in the request for the duplicate, the Risk Analysis team confirmed that two agents from the Sales Point of the store at C/ Jorge Juan, 6 ORANGE MADRID

***ADDRESS.1 acted irregularly, using their credentials from the internal systems of this company to activate the duplicate SIM card.

In this regard, it was verified that, at the time of contracting, the protocol established by this company was followed passing (...) [...]. This system allows identifying that (...). However, despite the fact that the instructions given to the distributors were followed, since it was the agents who acted irregularly, (...)."

They also indicated that:

"[...] this company has taken the appropriate legal measures within its power, notifying the distributor of the need to file a complaint against the agents for whom they are responsible.

Additionally, in order to minimize the possibility of the reported incident occurring again, the company has proceeded to track (...).

Furthermore, on December 28, 2022, prior to the notification of this requirement, a mandatory training module was distributed from the School of Sales to the entire distribution channel at the Sales Points to help and raise awareness among the sales teams about the risk of recruiting salespeople to physically duplicate from the Sales Points.

Finally, this company proceeded to refund the amounts charged for the SIM change in the January 2023 invoice."

THIRD: On February 3, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following aspects:

In the present inspection actions, ORANGE was requested to provide a detailed description of the Identity Verification System, the operation followed with this system, and detailed information on the checks carried out on identity documents. Confirmation was requested that this system (...).

ORANGE responded in this regard as follows:

Upon the request for a commercial act at a sales point, the agent collects the identity document of the applicant (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/120

As a general rule, the system does (...). However, (...).

It was this circumstance, in the case at hand, that allowed the agents (...) to carry out the fraudulent duplication of the SIM by usurping the identity of the claimant and thus failing to carry out the pertinent

(...), which is why they were able to execute the operation.

ORANGE has also been requested to provide a copy of the contract signed with the distributor in question, as well as a copy of all instructions available regarding the (...) of customers in the context of SIM duplications. A copy of the instructions regarding the use of the (...) was also requested.

They provide a copy of the instructions, published according to the documentation provided in "Discover Orange," section "Residential," "Necessary documentation for the registration and other commercial acts of a customer V26" "Special reference to fraud in unauthorized SIM changes," specifying for the point of sale that "the replacement SIM will never be delivered to a person other than the holder, even if they have a signed authorization."

It also states that "the customer's document will always be validated in (...)" "if at that moment (...) an incident will be opened and the customer will be asked to return the next day." The same is indicated for obtaining the SIM as for a SIM change.

They also provide a screenshot showing the tool used at the point of sale, which for SIM cards includes a "Documentation" button, which is specified to invoke (...).

They state that, exceptionally, (...).

They provide a copy of the contract with the franchised entity in question. In the Object of the contract, among other activities, it states "Replacement of SIM cards." It contains a clause, the twenty-second, regarding the processing of personal data and the twenty-third, regarding confidentiality.

Regarding the reasons why the agents acted irregularly, the representatives of the responding party state that it has been confirmed that during the first months of 2023, attacks at points of sale have increased, recruiting agents to carry out criminal acts in exchange for large financial rewards (CAT, Anti-Fraud Committee Telco). In this case, the distributor was informed of the need to take appropriate legal measures by filing a complaint against the agents for whom they are responsible. The distributor filed it, and preliminary proceedings No. XXX/20XX were opened in the Court of Instruction No. 53 of Madrid.

Regarding other measures taken to prevent these events from happening again, ORANGE indicates that the fraud prevention, security, and DPD office teams have promoted the dissemination to the entire distribution channel of a training module aimed at raising awareness among employees about the existing problem and the obligation to comply with all customer identification procedures and policies.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/120

They provide the URL where the informational pill is published, verifying that it contains a section on context/background, which indicates, among other circumstances, the high risk of SIM swapping and the necessity to strictly comply with all procedures and the customer identification policy using the identity verification tool.

In the section Legal Actions, the legal actions and consequences that may arise from non-compliance with the guidelines prescribed by the company are mentioned, including disciplinary sanctions for the employee who has engaged in irregular conduct, as well as that judicial authorities may consider that the employee who has violated the guidelines established by the company is a necessary collaborator in the commission of a criminal offense, which may entail prison sentences and economic compensation for the customer who has been harmed by the action of SIM swapping.

In the "Use Cases" section of the informational pill, it specifies, among other cases, (...). There are 13 use cases accessed.

Finally, ORANGE has been requested to provide the contacts maintained with the claiming party, verifying that there is a contact dated November 16, 2022, in which the operator records the customer's complaint about the duplicate SIM, as well as that a SIM change was made the day before. They recommend the customer change the password for the customer area.

FIFTH: According to the report collected from the AXESOR tool, the entity ORANGE ESPAGNE, S.A.U. is a large company with a sales volume of (...) and 3,068 employees.

SIXTH: On November 28, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 6 of the GDPR and Article 25 of the GDPR, classified under Article 83.4 of the GDPR and Article 83.5 of the GDPR.

This initiation agreement, which was notified to ORANGE in accordance with the rules established in the LPACAP, was recorded on November 28, 2023, as evidenced by the acknowledgment of receipt in the file.

SEVENTH: On November 30, 2023, ORANGE submitted a document requesting an extension of the deadline to present allegations and for a copy of the file to be provided.

EIGHTH: On December 4, 2023, the instructing body of the procedure agreed to extend the requested deadline by a maximum of 5 days, in accordance with the provisions of Article 32.1 of the LPACAP, and that a copy of the file be sent to ORANGE.

The aforementioned agreement was notified to ORANGE on December 11, 2023, as evidenced by the acknowledgment of receipt in the file.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/120

NINTH: On December 21, 2023, a document from ORANGE was received by this Agency, in due time and form, in which it presents allegations against the initiation agreement. In these allegations, in summary, it stated:

Preliminary: reiteration of previously submitted allegations.

ORANGE expresses its disagreement with the content of the initiation agreement and reaffirms and reproduces the allegations and arguments presented in its previous documents, without prejudice to the authority it has to address, in these allegations presented, the points it considers most relevant and add elements to challenge the foundations contained in the initiation agreement of the present sanctioning file.

First: existence of criminal prejudiciality.

ORANGE states that the facts subject to the initiation agreement are, in turn, the basis of a criminal investigation in which it is listed as the harmed party, and is therefore subject to the principle of criminal prejudiciality provided for in Article 10 of Organic Law 6/1985, of July 1, on the Judiciary. Consequently, it states that the matter should be resolved in the criminal jurisdiction before a ruling is made in the administrative jurisdiction, and for this, it cites Article 22.1.g) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, to request the suspension of this sanctioning procedure, according to which, the maximum legal period for resolving a procedure and notifying the resolution may be suspended when obtaining a prior ruling from a judicial body is essential for resolving the procedure.

ORANGE bases its request for suspension on the provisions of Article 77.4 of the aforementioned Law 39/2015, according to which, in sanctioning procedures, the facts declared proven by final criminal judicial resolutions will bind Public Administrations regarding the sanctioning procedures they process. It also points out that criminal prejudiciality requires a triple identity of subject, fact, and foundation, for the principle of non bis in idem enshrined in Article 25 of the Constitution to be considered valid and applicable to the specific case.

Thus, ORANGE states that:

- Regarding the subject, the authorship of the facts in both proceedings by the commercial agents is confirmed.
- Regarding the fact, there is a coincidence as it concerns the fraudulent issuance of a duplicate SIM card.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

- As for the basis, it would be sanctioning on two occasions for the illegitimate and fraudulent conduct of the agents, contrary to the protocols and procedures established by ORANGE.

Finally, it states that it submits, as document 1, the complaint filed by the distributor against the implicated agents, and as document 2, the written notice of ORANGE's appearance in the criminal case as an injured party.

Second: regarding the factual assumption.

ORANGE provides a narrative of the facts, which can be summarized as follows:

- On November 15, 2022, the claiming party realized that they had no line on their mobile phone and went to an ORANGE establishment to resolve the incident. At this moment, it was confirmed that a duplicate of their SIM card had been fraudulently produced, leading to its deactivation, thus resolving the incident that is the subject of the complaint.

- When the incident was known, it was referred to the Risk Analysis Group, confirming the duplication of the SIM card, which was activated by a commercial agent at the ORANGE store on December 15, 2022. The risk analysis team concluded that the two agents at the point of sale had acted criminally with fraudulent intent, using their knowledge and internal systems to activate the duplicate.

- In this case, (...).

The ORANGE protocol establishes that, while a notice must be generated to the Risk Analysis Group, it allows commercial agents, in specific cases, to continue the process (...). This is permitted in cases of (...). Therefore, ORANGE considers that the agents took advantage of their knowledge of the system to commit the criminal act.

- ORANGE wishes to point out that before receiving the first request for information sent by this AEPD in this case, it had already communicated, through the Risk Analysis Group and through the School of Commercial Agents, a mandatory reinforcement brief for all points of sale, which raised awareness and provided information aimed at fostering collaboration from the commercial teams.

- On January 16, 2023, the company TOWER PHONE, S.L., which includes the distributing company to which the point of sale belongs, filed a complaint with the Madrid Investigating Court against the two agents who participated in the duplication of the SIM card.

ORANGE wishes to state that the issuance of a duplicate SIM card involves issuing a SIM card without personal information, and that by itself, it does not allow access to banking or financial information.

ORANGE makes this statement because it understands that this AEPD uses erroneous associations in the initiation agreement to aggravate the factual assumption that concerns us, granting the duplicate SIM card the ability to allow the commission of banking operations, omitting a prior step, according to which, the wrongdoers must obtain and be able to use the banking credentials of the claiming party to be able to identify themselves and, first of all, commit identity theft before their financial institution.

It adds that this AEPD does not mention the role that financial institutions play in these cases, nor is there any record that, despite the economic harm to the claiming party, sanctioning procedures have been initiated against them. It considers that this AEPD cannot sustain the imputation of guilt to this company based on mere statements absent of evidence, regarding which, in any case, it would be necessary to evaluate the intervention and responsibility of the affected entities.

It adds that the AEPD intends to sanction SIM Swapping frauds without addressing or analyzing the specific factual assumption, the associated harm, or the derived responsibilities, without taking into account the diligence displayed by ORANGE in its actions and in the adoption of security measures. In this regard, it wishes to mention the ruling of the National Court 6460/2022, dated December 23, 2022, which annulled, for being contrary to law, resolution PS/00070/2019, and in which it is stated: "The AEPD does not examine these complaints that refer to specific facts nor does it make an assessment of the evidence presented in relation to them in the legal grounds, nor do they connect with the privacy document, but rather uses them to open a kind of general case against the privacy policy."

ORANGE wishes to state that, as in this procedure, this AEPD does not refer to the specific factual

assumption and omits to assess the documentation provided, establishing a generic discourse to legitimize an infringement of data protection regulations. It adds that this AEPD has imposed various sanctions on ORANGE for complaints related to SIM Swapping in which the same legal reasoning is reproduced regardless of the facts or circumstances concurrent in each case. It adds that this procedure is contrary to what is stated in the aforementioned ruling of the National Court, which emphasizes the need for the AEPD to rigorously examine compliance with the principles of the sanctioning administrative procedure in its resolutions.

Third: on the role of the victim of ORANGE. On the Modus Operandi.

ORANGE provides a summary of the background of frauds with characteristics similar to "SIM Swap," noting that initially, identity thefts requested duplicates of SIM cards in person, while currently, they focus on the request for duplicates and activation of SIM cards through non-presential channels.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/120

In the present sanctioning file, the duplicate of the SIM card is carried out by two sales representatives from the company's point of sale, who were acting, consequently, on behalf of ORANGE.

Therefore, ORANGE states that when the agents decide to commit the crime, taking advantage of ORANGE's means and systems, frustrating its procedures and security measures, ORANGE's role is that of the harmed party, since the commission of the crime is carried out by its agents, thereby breaching its contractual obligations to ORANGE and its distributors. For this reason, it understands that it is not possible to demand from this company the total capacity to detect and prevent such criminal acts.

At this point, ORANGE wishes to cite Order 35/2023, from the Criminal Chamber, Section 3 of the AN, dated January 30, 2023, which dismisses an appeal filed by the Public Prosecutor's Office, confirming the dismissal and filing of the investigation piece regarding the responsibility of two legal entities. Thus, in its Legal Basis 2, concerning crime prevention models and the associated responsibility of the legal entity, it specifies:

"SECOND. – We reject the grounds for appeal alleged by the Public Prosecutor's Office, accepting and reproducing the reasoning of the appealed order and the cited jurisprudence regarding the criminal liability of legal entities in the order of 29.07.2021, to which the order of 02.06.2022 refers in some aspects. At the time the contracts were made with (...) referred to in this procedure, (...) had a Crime Prevention Model that met the requirements set forth in Article 31 bis of the Penal Code. No model is infallible, and if a crime is committed by any of the subjects contemplated in the cited provision, it does not necessarily imply that the crime prevention model adopted by the legal entity is inadequate, violates current regulations, or fails, as it would suffice to adopt a model that complied with all the rules to prevent the commission of crimes, which does not align with reality, and precisely for this reason, crime prevention models are subject to periodic reviews."

Based on this, ORANGE wishes to express that the Courts have been recognizing that the commission of a crime, even when committed within a legal entity, does not automatically determine guilt or lack of diligence.

Furthermore, it states that ORANGE has documented the implementation of specific and adequate measures, as well as a procedure for requesting duplicates of SIM cards, so it cannot be presumed that there was negligent conduct.

For this reason, it wants to reiterate that ORANGE is a victim of a criminal attack carried out through its own systems and from one of its points of sale. Moreover, this is the first time such an incident has occurred, being entirely novel.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Fourth: Regarding the non-existence of a lack of standing in the processing of personal data of ORANGE.

ORANGE states that, during the process of duplicating the SIM card that led to the initiation of this sanctioning procedure, ORANGE did not provide any personal data of the complaining party to any third party, and there was no disclosure or unauthorized access to their personal data.

It adds that the sanctioning file does not contain any other processing of data that could be classified as unlawful, and there is no relationship between the facts that the AEPD identifies as proven and the legal qualification made of them.

It understands that the commission of the criminal acts is carried out by the agents individually, and in opposition to the obligations imposed by ORANGE, its procedures and protocols, and therefore, it cannot be automatically attributed to an action of ORANGE. In this regard, they provide as documents 3 and 4 the contract signed with the franchisee responsible for the processing, as well as the addendum for the novation of the same, to exemplify the contractual obligations assumed by the agents.

On the other hand, ORANGE points out that in the initiation agreement it is indicated, on page 6: "On the other hand, the issuance of a duplicate SIM card involves the processing of the personal data of its holder, as any person whose identity can be determined, directly or indirectly, particularly by means of an identifier (Article 4.1) of the GDPR, will be considered an identifiable natural person. Therefore, the SIM card identifies a phone number and this number, in turn, identifies its holder. In this regard, the Judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec, 2003 p.I-12971: The concept of "personal data" used in Article 3, paragraph 1 of Directive 95/46 includes, according to the definition set out in Article 2, letter a), of that Directive, "any information relating to an identified or identifiable natural person." This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies.

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally and uniquely identifies the subscriber on the network are personal data, and their processing must be subject to data protection regulations."

In this regard, it refers to the Judgment of the General Court of the European Union (Eighth Chamber extended) of April 26, 2023, which determines that the consideration of an alphanumeric code as personal data cannot be presumed, but rather it is the responsibility of the supervisory authority to justify the ability to relate personal data to a specific person, and it is not sufficient to presume it merely because it could potentially allow for identification.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

In this regard, this ruling states that it is the responsibility of the control authority to "determine whether the possibility of combining the information that had been transmitted to (...) with the additional information held by (...) constituted a means that (...) could reasonably use to identify the authors of the comments." It adds that: "Therefore, since (...) did not investigate whether (...) had legal and practically feasible means to access the additional information to re-identify the authors of the comments, (...) could not conclude that the information transmitted to (...) constituted information about an identifiable natural person, in the sense of Article 3, point 1, of Regulation 2018/1725."

ORANGE wishes to express that no evidentiary activity has been deployed by this AEPD in this regard, but rather it directly presumes that the codes contained in the SIM card allow for the identification of its holder.

It adds that the fact that the codes technically allow for differentiating a user from others on the network for the proper management of communications does not imply that the parties involved in the process have the possibility of associating that information with a specific person, and, considering the ruling of

the General Court, we would not be facing a case of unlawful processing of personal data.

At this point, ORANGE cites the Supreme Court ruling of June 18, 2020 (case number 1074/2019, ruling number 815/2020) which states, in the case of a telephone number, that its consideration as personal data is questionable, in the following sense:

"Well, in the case at hand, apart from the telephone number of the affected complainants, which by itself could not be considered personal data according to the ruling of this Chamber of September 17, 2008 (Rec. 353/2007), DIRECCION001 also proceeds to record the voice of the complainants through the appropriate recording of the prank, which is susceptible to being disseminated."

Thus, according to this ruling, even in the case of a telephone number, its consideration as personal data must be justified, and it cannot be presumed for the codes, whose ability to be related to the holder of the line depends on the availability or access to other data of the same.

In this sense, ORANGE understands that the codes (MSISDN and IMSI) are not directly accessible information, but rather involve carrying out specific activities with the mobile device, so it would not be appropriate to attribute unlegitimized data processing merely due to the possession of the card, and without it being considered, as previously mentioned, as personal data. Furthermore, it adds that, even if it were interpreted that the technical information contained in the SIM card could be considered personal data, there is no evidence of its knowledge by the authors of the criminal act, so there is no basis to conclude that there has been unlawful processing of that data.

ORANGE points out that the statement included in the initiation agreement "In the present case, it is evidenced that a duplicate of the SIM card has been produced by the complaining party to a third party, without their consent, and without counting on..."

14/120

Your DNI", would not reflect the specific facts, since, as ORANGE states, there is no record of any third-party intervention; rather, it is the agents of ORANGE themselves who access, by virtue of the permissions granted to them, to perform their work obligations, to the tool normally, as authorized users, and knowing the tool (...), they made fraudulent and criminal use of it.

ORANGE states that it is not possible to eliminate the human factor entirely in the management of ORANGE's processes, as it is sometimes necessary to validate documents that may not be automated. It also considers that adopting control measures for employees or maintaining exhaustive oversight of their activities or sanctioning non-compliance with established protocols is not compatible with labor regulations, and that it is not possible to demand absolute effectiveness of the measures designed to prevent fraud, or, in terms of risk analysis, it is not feasible to require the existence of effective measures that guarantee a "zero risk," as this would imply, in fact, the realization of objective liability.

Furthermore, ORANGE states that it does not consider it proportional to assume that merely duplicating the SIM card could lead to "the production of a significant patrimonial loss" as indicated on page 6 of the initiation agreement. It understands that ORANGE agents did not access the claimant's mobile phone or the information it contains, and insists that the SIM card does not contain the data of the mobile terminal or the installed applications, and to access such applications, one must know the banking credentials. Therefore, they believe that the initiation agreement cannot sustain its accusation based on statements lacking evidence, which mention facts that do not occur in this case. They assert that this claim does not derive from any proven fact and violates the principle of legality and the presumption of innocence of ORANGE, by attributing guilt without sufficient evidence.

Finally, they wish to express that it is not possible to attribute to ORANGE the processing of data without legitimacy, as the processing carried out by ORANGE is based on the existing contractual relationship with the claimant, as stated in Recital 40 of the reasoning. Therefore, they understand that there is no unlawful processing of the claimant's data, and thus an infringement of Article 6.1 of the GDPR cannot be attributed.

Fifth: on the correct implementation of privacy by design and by default.

ORANGE provides the following documents in relation to this matter:

- Document No. 5, relating to the "Privacy Management Dashboard" that is shared annually with the company.
- Document No. 6, a report containing the audit opinion regarding the application of privacy principles

by design and by default by ORANGE.

- Document No. 7, the company's data protection procedure by design and by default.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/120

On the other hand, it understands that the reasoning included in the initiation agreement regarding this non-compliance is scant, considering the extensive normative reproduction and the recitals related to this principle and the AEPD Guidelines on this matter.

It insists that this Agency does not take into account, in the initiation agreement, that the store agents are individuals contracted by ORANGE or by distributors and franchises, and that their role is to carry out hiring processes and other complementary tasks designed by the company, in which privacy and information security are indeed considered, including the involvement of the agents themselves.

It adds that the agents are tasked with executing the processes by ensuring that they are carried out correctly, according to the instructions provided by ORANGE, and that failing to do so would constitute a breach of contractual obligations, instructions, and internal protocols of the company.

ORANGE states that the automation of measures to support this work with digital means facilitates and complements it, but cannot be interpreted as an indispensable requirement, rather as a reinforcement.

Furthermore, it understands that the legitimate possibility for ORANGE to delegate supervisory tasks to designated users must be taken into account, without this constituting a regulatory breach, and that a blanket prohibition on decision-making by employees would be contrary to what the GDPR proposes. ORANGE asserts that the involvement of a person in the process does not necessarily imply that there is no security, or that it incites employees to commit crimes, or presumes that the generality of workers is more inclined to commit fraud than to perform their functions. It adds that this is the first time this has occurred.

Additionally, it understands that it is contrary to the criteria outlined in the Guide on presence control treatments using biometric systems, dated November 23, 2023, where it states:

“It is neither mandatory nor advisable for the implementation of a treatment to be limited exclusively to the selection of technological resources. In the options for implementing a treatment, one must consider, among others, the use of human resources, legal guarantees, and organizational procedures.”

Therefore, it understands that, in the case that has prompted the opening of this sanctioning procedure, in which, after identifying a technical error that prevents the execution of ordinary management, means are enabled (...) to carry out the operation, which must be considered as complementary, in such a way that the agent involved in the operation verifies (...).

ORANGE also wishes to point out that, at times, it is the clients themselves who demand agility in the processing of their requests, and that is why alternative verification means are enabled, which are previously subjected to the corresponding risk analyses.

ORANGE highlights that the prevention of fraud is entrusted to a specific department of the company, which evaluates risks according to a specific protocol and methodology, providing the following documents to support this:

- Document 8, related to the Group Risk Management Policy
- Document 9, Risk Control and Management Policy
- Document 10, which describes the functioning of the Local Risk Committee
- Document 11, which lists the Internal Control Policy of Orange
- Document 12, Fraudulent Use of Data - 3rd Parties, where there is a presentation that was brought to the Local Risk Committee, which expressly refers to the analysis of the evolution of this risk.

With this, ORANGE wants to express that it is incorrect to state that this type of risk has not been subject to analysis, but rather that it has been increasing in recent dates, due to the case that has prompted the opening of this sanctioning procedure, and it wishes to highlight that the risk had been classified as low, and therefore there was no need to implement additional measures beyond those already in place, without this implying that it acted in a corrective rather than preventive manner. As

preventive measures adopted, it wishes to point out:

- Legal measures: contract with the franchisee, including a confidentiality commitment (documents No. 3 and No. 4).
- Organizational measures:
 - Communication of instructions such as the informative pill provided to Orange Agents,
 - Access control and recording of actions executed by users, which requires the use of non-transferable personal credentials assigned by ORANGE, allowing for the identification of the agent and monitoring of their activity.
 - Error management protocol, (...).

ORANGE adds that, in this case, the individuals were dismissed and are currently facing criminal charges, and that these measures are a consequence of previously implemented deterrent measures to mitigate the risk of such actions occurring.

It insists that it cannot be accepted that allowing the agent to supervise the correction of a process implies that there is no control over the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/120

process or that this measure is not in accordance with the GDPR, and that this assertion implies that any process carried out by a person without digital control is inadequate, something that ORANGE finds unsustainable. It adds that digital control is susceptible to being incorrect or failing, making human oversight necessary.

ORANGE mentions in this regard Article 22 of the GDPR, relating to automated individual decisions, which includes the right of everyone not to be subject to a decision based solely on automated processing, as well as the right to obtain human intervention from the controller, and understands that the interpretation made by this AEPD that allowing a person to make decisions constitutes a breach of the GDPR is contrary to the spirit of the regulation, which aims to promote human intervention in processes to avoid biases, inaccuracies, or errors arising from fully automated processes.

In this way, it understands that considering human intervention before certain machine errors would be in accordance with the GDPR and is also a good practice. This is because it believes that it is never completely avoidable that a malicious user could carry out an unlawful action, potentially memorizing personal information of clients for illicit use.

ORANGE recalls that, in this case, it would have been a fraudulent action, intentional and aimed at benefiting personally and financially, and that, regardless of the fact that, after becoming aware of the event, the risk assigned to this potential fraud has been updated and appropriate measures have been taken to limit it, this action required voluntary identification before the commission and documentation of the fact.

ORANGE expresses its disagreement with the justification of the one million euro fine for the general breach of the principle of privacy by design and by default of the company, even though the risks of non-automated management of a request had not been analyzed. It adds that it is not true that the referred risk has not been taken into account, but that this cannot serve as a basis to assert that a general principle of the GDPR is being breached. It considers that this is a generic and ambiguous provision and that it remains a resource to try to classify a fact that, in essence, would not constitute a breach of a specific obligation, and that the fact of not having considered a threat could not invalidate the entire compliance system implemented by ORANGE.

Sixth: concurrence of infringements.

ORANGE understands that in this sanctioning file the circumstances exist to consider that there is concurrence between the two infringements attributed, as they are imposed based on a single act committed by the agents of ORANGE.

Thus, ORANGE understands that in the initiation agreement reference is made to a single fact, subject and basis, which would be the adoption of measures in the procedure for duplicating the SIM card in the specified cases of manual intervention, which would constitute a case of medial concurrence in

criminal law or a concurrence of offenses or crimes in administrative law, which applies "whenever the
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/120

the application of one provision prevents or subsumes the applicability of the other," and that it is contrary to the legal system to sanction the offender twice for the same offense.

ORANGE understands that, from the initiation agreement, it can be inferred that, in relation to the analyzed facts, there is a direct connection between the violations of the two articles.

In this way, the infringement of Article 6.1 GDPR, or the existence of an alleged unlawful data processing, was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, derived from the lack of sufficient security measures. Thus, if ORANGE had had measures that would have prevented the duplication of the SIM card, the infringement of the principle of privacy by design and by default under Article 25 of the GDPR could not have been concluded. Consequently, there would be a concurrence of offenses, as the commission of one would necessarily imply the commission of the other.

ORANGE cites the Judgment of the National Court of April 24, 2013, Rec. 69/2011, according to which:

““To assess this infringement, it is essential, in the opinion of the Chamber, to refer to the concurrence of offenses whose existence is also invoked in the complaint. To this end, it is necessary to bring to light the provisions of Article 4.4 of Royal Decree 1398/1993, according to which: in the absence of specific regulation established in the corresponding norm, when the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.

This provision has been interpreted by the Supreme Court ruling of February 8, 1999 (Rec. 9/1996) in the sense that the application of the concurrence of offenses requires a necessary derivation of some infringements concerning others and vice versa, so it is essential that the former cannot be committed without executing the latter.”

ORANGE understands that, if an infringement of Articles 6.1 and 25 of the GDPR is appreciated, it would be a case of concurrent infringements, and that the applicable sanction would, in any case, correspond to the breach of Article 6.1 GDPR, taking into account the provisions of Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, according to which:

“when the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.” In addition, it refers to the Guidelines 4/2022 on the calculation of administrative fines under the GDPR, where the criteria that the administrative authority must follow to evaluate, prior to the imposition of the sanction, the possible concurrence of these are stipulated.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/120

Seventh: on the inadmissibility of objective liability.

ORANGE points out that the initiation agreement of the present sanctioning file is based on a result analysis, considering that the issuance of the duplicate SIM card automatically entails the consideration that adequate measures were not taken, thus automatically arising direct liability on the part of ORANGE, establishing an obligation of result.

ORANGE considers that this AEPD limits the obligation to the result, by stating that the overcoming of security measures by ORANGE agents automatically entails the consideration that the measures were insufficient, and that this fact implies adopting a principle of objective liability prohibited by our legal system on numerous occasions by the Constitutional Court.

ORANGE refers to the principle of liability in Article 28 of Law 40/2015, of October 1, which breaks with objective liability and ties liability to the concurrence of intent or fault.

In this way, ORANGE refers to the Judgment of the Constitutional Court 76/1990, of April 26, in which it would be required that the Administration, when sanctioning, prove the intentionality of the sanctioned party. It adds that, in this ruling, it was pointed out that the possibility of imposing a sanction requires the concurrence of culpability in the degrees of intent and fault or gross negligence, mere negligence being insufficient, as expressed in this way:

“mere human error cannot, by itself (and especially when it occurs in isolation), give rise to the attribution of sanctioning consequences; for, if this were done, it would incur a system of objective liability prohibited by our constitutional order.”

ORANGE states that this extensive interpretation of sanctioning power has also been categorized as unacceptable by the Court of Justice of the European Union in some rulings, citing:

-C-683/2021, referring to the material requirements that must be met to impose an administrative fine under the GDPR.

Thus, ORANGE understands that since the concurrence of a culpable, intentional, or negligent act on the part of ORANGE has not been accredited, the conduct cannot be identified as an infringement of data protection regulations simply because it was a victim of a criminal act, and therefore the imposition of a sanction is not appropriate.

In relation to objective liability, it cites the Judgment of the Supreme Court 5298/1994, of July 9, the Judgment of the Administrative Litigation Chamber of the National Court, Section 1 of December 23, 2013, Rec. 341/2012; Judgment of the Administrative Chamber of the National Court, of February 25, 2010, Resource 226/2009; Judgment of the Supreme Court 543/2022, of February 15.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/120

In relation to the Judgment of the Supreme Court 543/2022, dated February 15, which stated that “the obligation to adopt the necessary measures to guarantee the security of personal data cannot be considered as an obligation of result, which implies that if a personal data breach occurs to a third party, there is liability regardless of the measures adopted and the activity carried out by the responsible party,” and adds that “the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in its implementation and use, aimed at achieving the expected result with means that can reasonably be classified as suitable and sufficient for its achievement; therefore, they are referred to as obligations of diligence or behavior.”

ORANGE considers that while in the obligation of result one is liable for a harmful result due to a failure of the security system, in the obligation of means it is sufficient to establish technically adequate measures and to implement and use them with reasonable diligence. Therefore, it considers that this initiation agreement is not in accordance with the law, as it imposes on ORANGE an obligation of result, which would consist of establishing infallible measures, by attributing a violation of Article 6.1 and Article 25 of the GDPR based on the harmful fact that occurs due to the fraudulent intervention of a third party, without considering the diligence used and without taking into account the deployment of technically adequate and implemented measures.

It adds that it would not be feasible to implement unbreakable measures, since any measure has vulnerabilities, nor is it required by the applicable regulations, and that this Agency undertakes a general cause against SIM Swapping, sanctioning the mere fact that they occur, without analyzing the specific factual situation, the associated harm, or the derived responsibilities, and concluding the violation of data protection regulations merely by having been a victim of criminal activity, and without considering the diligence deployed by ORANGE in its actions and in the adoption of security measures.

Eighth: regarding the measures adopted and implemented by ORANGE.

ORANGE states that it has adopted the following measures, both prior and subsequent, in relation to the procedure for issuing duplicate SIM cards.

1. Measures implemented to prevent fraud resulting from identity theft.

a) The analysis and risk group periodically issues an instruction manual titled "Necessary Documentation and Delivery Formats for Commercial Acts with Customers v.26," which includes the instructions to be followed to analyze any commercial act, including the duplication of SIM cards. In relation to the request for a duplicate or activation of a SIM card, the instructions that ORANGE agents must follow are included, among which is the requirement to provide an identity document.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/120

They attach as document 14, some screenshots of the tool "discover ORANGE" with the information collected in the document for these purposes.

b) ORANGE communicates that additional communications are issued reiterating the action protocols in the processes of duplicating SIM cards.

c) Information and awareness campaigns directed at customers, to emphasize the importance of securely safeguarding their credentials and identity documents.

d) Other measures and modifications in their commercial and business processes:

- since August 12, 2022 (...).

- since August 12, 2022, the request for a duplicate SIM card (...).

- since April 2021, ORANGE has limited the channels for requesting a duplicate SIM card (...).

e) ORANGE is part of the Spanish Association for Digitalization and participates in the "secure digital identity" project, which aims, among other things, to protect against fraud and cyberattacks and to defend data privacy.

ORANGE markets the "SIM Swap service" application that allows verification (...).

2. Measures implemented by ORANGE to prevent fraud resulting from the impersonation of ORANGE agents and/or employees.

a) Implementation of a two-factor identification system, with a pilot project in the testing phase with certain users.

b) Project (...).

c) Traffic control tool, used as a security measure in the prevention and detection of fraud, which allows the generation of alerts in case of detection of irregular contracts, and which in the case of duplicate SIM cards would act as follows:

- (...).

- (...).

3. Measures adopted by ORANGE concerning the present case, not included in the previous sections.

a) Internal investigation, which has identified the causes and mitigated the possibility of similar situations occurring.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/120

b) complaint filed by the distributor of ORANGE with the Security Forces and Corps against the agents responsible for the Point of Sale who committed the criminal act, in which ORANGE has appeared as the injured party.

c) since December 14, 2022, ORANGE has proceeded to provisionally suspend the option that allows point of sale agents, (...). With these measures, ORANGE considers that it has demonstrated both the intention to protect the rights of individuals and the application of an appropriate level of diligence on the part of ORANGE, which is updated and reviewed periodically in accordance with the state of the art, the costs of application, the nature, scope, context, and purposes of the processing.

Ninth: lack of proportionality of the imposed sanction.

ORANGE states at this moment that it has demonstrated having acted with due diligence in the implementation of measures in the processes of duplicate SIM cards, and that in this case the agents acted individually and fraudulently breaking the standards and protocols of the company. In any case, it understands that the sanction included in the initiation agreement is disproportionate considering the circumstances and content of the alleged infringement, which ORANGE denies.

ORANGE wishes to express its disagreement with the interpretation made by this Agency regarding the aggravating factors:

a) the nature, severity, and duration of the infringement (Article 83.2.a) GDPR). ORANGE states that this aggravating factor is based on the possible commission of fraudulent banking operations. It understands that it is not legally acceptable to use as an argument the use of bank accounts, the monetary damages of the victims of the frauds, or the manner in which these operations are carried out by financial entities to justify the sanction imposed on ORANGE, to the extent that "the banking entities are the only ones responsible for the security of their operations," as stated by the European Banking Authority in "Opinion on the implementation of the RTS on SCS and CSC" points 37 and 38, where it is determined that the security credentials used to perform the secure authentication of users of payment services are the responsibility of the account management entity.

Regarding the aggravating factor related to the infringement of Article 25 GDPR, ORANGE understands that the initiation agreement takes into account all ORANGE customers in their entirety, which amounts to 21 million customers. ORANGE wants to express that not all these customers are natural persons, nor do all request a duplicate SIM card, and therefore cannot be considered as potentially affected. To make this statement, it cites the guidelines 04/2022 of the EDPB, in which, when referring to the "interested parties" potentially affected, it would be referring to natural persons, and in the sense of involved interested parties, or interested parties who, although they have not directly perceived the harm or have been affected by its effects, fall within the factual assumption. Therefore, ORANGE understands that, in this factual assumption, there is a single implicated party, which would be the person who filed the complaint.

Furthermore, it understands that the EDPB's mentions of involved interested parties are not applicable in the case of SIM Swapping, caused by a fraudulent and malicious act, and especially in a case like this, where the agents acted maliciously against ORANGE's own systems.

b) any previous infringement committed by the data controller or processor (Article 83.2.e GDPR) ORANGE states that this Agency's assessment of previous infringements imposed for the violation of Article 6.1 GDPR has nothing to do with the present factual assumption. Furthermore, in terms of classification, ORANGE has not had a resolution or administrative procedure for the infringement of Article 25 GDPR. Therefore, it understands that this Agency cannot consider, as previous infringements, any type of infringement, without making distinctions in the types and provisions of the regulation, treating all administrative procedures (which are mostly appealed and without a firm resolution in judicial proceedings) as if they were criminal records.

It also wants to reiterate the particularities of the present sanctioning procedure, referring to the commission of a criminal act by ORANGE agents, with no data being made available to unauthorized third parties, nor any identity theft of the claimant before ORANGE taking place. Additionally, it insists that this is an isolated, punctual, and unprecedented case, and that this particularity must be taken into account, and cannot be assimilated to other cases where the fraud consisted of an external attack, with identity theft in person or through a call or recording.

c) the link between the business activity of the accused and the processing of personal data of customers or third parties (Article 83.2.k GDPR in relation to Article 76.2.b) LOPDGDD.)

ORANGE states that this factor is ambiguous in its assessment to include it as an aggravating factor, as such a link does not imply a direct relationship with the alleged infringement. ORANGE understands that Article 83.2.k) requires that this aggravating factor be related to the specific factual assumption and, therefore, the processing of data does not arise from an intention of the entity, but rather the commission of a crime takes place.

24/120

against the own systems of ORANGE, and that for this reason ORANGE is the injured party, and for this reason, this aspect cannot be interpreted as an aggravating factor.

d) intent or negligence in the infringement.

ORANGE states that this Agency does not relate this aggravating factor, nor does it indicate its application to the present case of fact.

Thus, it understands that, as stated by the CJEU when it indicated that the imposition of coercive sanctions by the administrative authority is only admissible in cases where culpable conduct by the responsible party or data processor is evident, the imposition of this aggravating factor should be reserved for cases where intent or negligence is evident or serious.

Therefore, in this case, where the alleged infringement is caused by a criminal act not attributable to ORANGE, it understands that this aggravating factor should not be attributed without any reasoning in this regard.

On the other hand, ORANGE believes that the following mitigating factors should have been taken into account:

- the party being claimed blocked the line as soon as it became aware of the facts. (art. 83.2.c)
- no special categories of data have been processed (art. 83.2.g)
- the degree of cooperation of ORANGE with the AEPD. Thus, ORANGE wants to state that it has been demonstrated that it has responded in a timely and proper manner to all information requests made, in order to remedy an alleged infringement and mitigate its possible adverse effects (art. 83.2.f)
- adherence to codes of conduct under Article 40 or certification mechanisms approved under Article 42 (art. 83.2.j)

ORANGE provides as document No. 15 a certificate issued by AENOR, which certifies that ORANGE has had an approved compliance system since September 4, 2023, which meets the requirements of Article 31 bis of the Penal Code, as well as the other compliance standards in the area of crime prevention, such as Circular 1/2016, of January 22, from the Attorney General's Office, aimed at mitigating any risk of committing crimes in the framework of ORANGE's actions.

- the nonexistent benefit obtained by ORANGE in the processing of the data involved in this sanctioning procedure, adding that, in any case, it would be harmed, as already pointed out, being an injured party in the criminal procedure in which the commission of the crime in question is reported (83.2.k)

Finally, ORANGE wants to record and demonstrate that the measures in place at the time of the alleged infringement complied with the most rigorous norms, guidelines, standards, and recommendations to address the risks, and that they were adequate and suitable considering the state of the art, the costs of implementation, and the nature, scope, context, purposes of the processing, and the risks to the rights and freedoms of individuals.

To conclude, it requests the filing of the present procedure, and subsidiarily, that the mitigating circumstances be taken into account and that the procedure be concluded with a warning, or that if it is deemed appropriate to impose a sanction, that the proposal contained in the initiation agreement be moderated or adjusted.

TENTH:

On June 21, 2024, a proposal for resolution was made, proposing that the Director of the Spanish Agency for Data Protection sanction ORANGE ESPAGNE, S.A.U., with NIF A82009812,

- for an infringement of Article 6 of the GDPR, classified in Article 83.5.a) of said regulation, with an administrative fine of 200,000 euros (two hundred thousand euros).
- for an infringement of Article 25 of the GDPR, classified in Article 83.4 of said regulation, with an administrative fine of 1,000,000 euros (one million euros).

That the Director of the Spanish Agency for Data Protection orders ORANGE ESPAGNE, S.A.U., with NIF A82009812, that pursuant to Article 58.2.d) of the GDPR, within 6 months, notify this Agency of the measures it has adopted to ensure that the duplicate request is submitted by the line holder, regardless of the procedure used for its issuance.

This proposal for resolution, which was notified to ORANGE in accordance with the rules established in the LPACAP, was received on June 25, 2023, as evidenced by the acknowledgment of receipt in the file.

ELEVENTH: On June 26, 2024, a written submission from ORANGE was received by this Agency requesting an extension of the deadline to submit allegations to the proposal for resolution, which was

granted on June 28, 2024.

TWELFTH: On July 17, 2024, a written submission from ORANGE was received by this Agency, in a timely manner, in which it presented allegations to the proposal for resolution. In these allegations, in summary, it stated:

ORANGE reiterates the allegations presented to the initiation agreement. Furthermore, it wishes to state:

First. - On the existence of criminal prejudiciality.

ORANGE expresses its disagreement with what has been stated by this AEPD regarding this issue. Thus, it states that the party that committed the infringement was the agents contracted by the distributor of the ORANGE brand. It adds that this is particularly relevant because depending on what is determined regarding the actions of the agents and the type of crime that is applied to them, it will condition the potential attribution of responsibility to ORANGE.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/120

Regarding the fact, it is stated that the coincidence is evident.

And regarding the basis, it is stated that there is an incompatibility between the imposition of an administrative fine on ORANGE resulting from a criminal act of which it is a victim.

It is added that the AEPD intends for ORANGE to respond administratively for a criminal offense committed by agents of its distributors, merely because the crime is carried out by fraudulently manipulating the functioning of its system. In this way, it is pointed out that the distributor is a franchised company, belonging to the distribution channel, external to ORANGE, which acts as the data processor, and the offense committed is carried out by the workforce of that franchise, against the documented instructions of my represented party.

ORANGE adds that this AEPD must assume that the conduct of the agents constitutes a criminal offense.

Second. Regarding the factual assumption.

2.1. Regarding the consideration of the SIM as personal data.

ORANGE states that this Agency interprets that the SIM card not only contains but is personal data in itself.

It also insists that there is no record of any information that could be contained in the SIM card being processed.

It adds that a duplicate SIM card implies the issuance of an empty SIM card, which would not allow access to banking or financial information per se.

Regarding the IMSI, it would be a code contained within the SIM card with a technical purpose, and it is not directly accessible. Furthermore, there is no evidence that this data has been accessed by the agents in the commission of the crime.

In this regard, ORANGE adds that, although it could be considered that this information potentially makes the line holder identifiable, the possibility of identification by third parties other than the operator would require additional information to which they do not have access.

2.2. Regarding the execution of banking operations.

ORANGE considers that this Agency uses these associations to aggravate the factual assumption underlying this sanctioning procedure, granting the duplicate SIM card the ability to allow the commission of banking operations, overlooking a prior step where criminals must obtain and use banking credentials to identify themselves and carry out identity theft before the financial entity.

It insists that this Agency does not analyze the responsibility of the banking entities affected by identity theft.

Moreover, ORANGE understands that this Agency is transferring responsibility for a banking operation to ORANGE, qualifying the obligations of operators and those of banking entities as identical.

In its written allegations to the proposed resolution, ORANGE provides statements in which it wishes to

express its disagreement with the fact that no action has been initiated for the banking entities to inform about the functioning of their systems.

It continues by stating that it is worth asking why banks implemented a reinforced authentication system in 2019 considered insecure, violating Article 32 of the GDPR, and why information has not yet been requested in this regard.

It insists that this Agency is transferring responsibility for a banking operation to ORANGE, unjustifiably qualifying the obligations as identical. It mentions at this point statements from the European Banking Authority, which would refer to the fact that banking entities are the only ones responsible for the security of their operations.

It adds that ORANGE cannot be held responsible for the configuration of SMS sending as a second factor of authentication used by those responsible for other services such as banking operators. In this sense, it mentions Judgment 142/2024, of March 21, 2024, from the Provincial Court of Oviedo, in which the victim had clicked on a link sent via SMS, resulting in unauthorized access to their customer area, and a transfer of 6,000 euros from the bank account, and in which the Provincial Court reiterated the culpability of the banking entity.

2.3. Regarding the relationship of the authors of the criminal act with ORANGE.

ORANGE states that the agents are employees of a distributor of the ORANGE brand, which holds the role of Data Processor according to the provisions of Article 28 of the GDPR. It adds that it is the data processor who must, when acting on behalf of ORANGE, have the corresponding means to detect and prevent fraudulent actions by its employees. In this regard, they refer to labor legislation, stating that, under Article 20, paragraphs 2 and 3 of the Workers' Statute, the power of control lies with the employer of the employee, and therefore, in this case, it would depend on the distributor of the ORANGE brand.

ORANGE refers to the fact that this AEPD would have alluded to the possibility that ORANGE could establish control measures over the employees of its franchisee.

ORANGE adds that, under the provisions of the Workers' Statute, it is the distributor that must establish control measures and not ORANGE itself.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/120

And, finally, it is stated that it cannot be argued that there has been a breach of Article 6 by ORANGE since the fraudulent conduct corresponds to the employees of the data processor, who, contrary to the provisions of Article 28 of the GDPR, have not followed the instructions of the data controller.

Therefore, it is understood that the responsibility for the commission of the infringement of Article 6 of the GDPR should fall on the data processor.

Third. On the criminal conduct of the agents.

ORANGE states that this AEPD makes a simplistic analysis of the issues related to SIM SWAPPING, and that it cannot be expected that the existence of a type of infringement of this category implies that any of the ways in which organized crime may attempt to carry out this type of actions can be foreseen and prevented.

ORANGE insists that criminal activity evolves, and this requires the adoption of measures that were not foreseeable in advance.

In this way, in the case that has motivated the opening of this sanctioning procedure, ORANGE states that it is a new criminal variant, which implies that those who must fulfill a role as a guarantor of security not only fail to perform their function adequately but also intentionally attack that security, not being the previously detected threat.

ORANGE states that this Agency penalizes the mere fact that a SIM SWAPPING fraud case occurs, without attending to or analyzing the type of fraud committed in the specific case, the harm caused, or the derived responsibilities, but rather, regardless of the above, and without taking into account the diligence displayed by ORANGE in its actions and continuous adoption of security measures, it is

concluded that there is a violation of data protection regulations, merely for having been a victim of criminal activity.

ORANGE wishes to remind that, as a result of the diligent security measures and procedures it has implemented, criminals have been modifying their criminal techniques, which would constitute evidence that there is a procedure for requesting duplicate SIMs from ORANGE that has been designed with privacy in mind, and that involves the deployment of adequate security measures. It also adds that the emergence of these practices had already been highlighted in the "Telecom Anti-Fraud Committee" held in March 2023, a few months after the commission of the present case, confirming that in the previous months attacks were detected aimed at targeting sales agents at points of sale.

It adds that as a consequence of the possibility that store agents may be corrupted and may engage in criminal activities such as those that have occurred,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/120

has conducted a new risk assessment attributed to this threat, and provides as Document No. 1 said assessment.

Furthermore, it insists that allowing a store agent to make decisions on certain operational matters cannot be equated with a breach of the GDPR. It states that, as previously reported, the manual intervention of agents has been halted, but it wishes to point out that this is a preventive measure while determining the most suitable actions to mitigate the risk associated with this threat, as this measure significantly and negatively impacts the user experience, is not economically sustainable, and is not legally defensible.

It insists that such a restrictive interpretation regarding the intervention of an employee to make decisions clashes with the regulation of the GDPR which, contrary to what is intended by the AEPD, considers that the risk lies in the adoption of automated decisions without human intervention.

It adds that the purpose of the agent's intervention is to prevent, in specific and duly assessed cases, a potential system error from preventing the interested party from accessing a contracted service, allowing for the validation by the agent.

However, ORANGE believes that this AEPD categorizes the parameterization of a manual procedure for certain situations as a violation of Article 25 of the GDPR from the perspective of privacy and in light of the statements of this Agency to curb the possibility of identity theft in duplicate SIM cards. ORANGE insists that it has designed internal procedures, taking into account privacy, that serve to determine the means of processing and that are applied effectively.

It understands that what has allowed the commission of SIM SWAPPING fraud has not been the controlled and assessed flexibility of the procedure by ORANGE, necessary for assessed cases and under adequate guarantees, but rather the deliberate commission of an unlawful and malicious action by the agents contracted by the data processor of ORANGE.

ORANGE mentions at this point Order 35/2023 of the Criminal Chamber Section 3 of the National Court, dated January 30, 2023, which dismisses an appeal filed by the Public Prosecutor's Office, confirming the dismissal and archiving of the investigation regarding the responsibility of two legal entities.

In its Legal Foundation 2, regarding the models for preventing crimes and the associated liability of the legal entity, it specifies:

“SECOND. – We reject the grounds for appeal alleged by the Public Prosecutor's Office, accepting and reproducing the reasoning of the contested order and the cited jurisprudence on the criminal liability of legal entities in the order of 29.07.2021, to which the order of 02.06.2022 refers in some aspects.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

At the time the contracts with (...) referred to in this procedure were made, (...) had a Crime Prevention Model that met the requirements set forth in Article 31 bis of the Penal Code. No model is infallible, and if a crime is committed by any of the subjects contemplated in the aforementioned provision, it does not necessarily imply that the crime prevention model adopted by the legal entity is inadequate, violates current regulations, or fails, since it would be sufficient to adopt a model that complies with all the rules to prevent the commission of crimes, which does not align with reality, and precisely for this reason, crime prevention models are subject to periodic reviews.

With this, ORANGE wishes to express that the Courts have recognized that when a crime is committed within a legal entity, it does not automatically determine the entity's culpability or a lack of diligence on its part. It adds that it has documented the implementation of specific and adequate measures, as well as a secured procedure for duplicating SIM cards, thus understanding that there would not have been negligent conduct on its part.

Fourth. Regarding the lack of standing in the processing of ORANGE's personal data.

ORANGE wishes to state that the events occurred due to employees of one of its data processors. Therefore, when the resolution proposal states, "In relation to this issue, it is necessary to point out that the conduct of ORANGE's employees is not the subject of this sanctioning procedure, but rather it is about verifying whether ORANGE's actions comply with personal data protection regulations," ORANGE understands that this Agency expressly recognizes that it intends to hold ORANGE responsible for the actions of these agents, regardless of whether this conduct constitutes a criminal offense.

ORANGE believes that this approach is incoherent, as it overlooks that a company acts through individuals, and what is being judged is precisely whether the actions of a person outside the organization, contrary to ORANGE's instructions and clearly aimed at causing harm to it.

ORANGE understands that the fraudulent issuance of a duplicate by the Agents would not constitute an action attributable to the company, as the agents employed by ORANGE's distributor sought to commit a crime. It believes that this conduct is not assignable to ORANGE, as it would imply attributing a criminal act directed against itself.

ORANGE reaffirms that the events that occurred in this case are what should be analyzed to identify a possible violation of the regulations, and not potential infringements. It adds that the facts on which this possible violation of the regulations is based must be proven and certain, and it understands that it is not true that the duplicate of the SIM card was made by an employee of ORANGE, but rather by an employee of a third company, unrelated to ORANGE, that acted as a data processor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Thus, it cannot be attributed to ORANGE a lack of legitimacy in the processing of personal data by ORANGE, because what occurred was that through its systems, ORANGE merely carried out a processing procedure for a request for a duplicate SIM card, without having the capacity to recognize that the origin of said request stemmed from an unlawful act by the store agents, who should only initiate the process at the request of the customers, and whose function is precisely to ensure compliance with the process in its entirety, in accordance with the instructions received and under the security measures and identity verification guarantees ordered by ORANGE.

Additionally, in the present case, during the duplication process, the personal data was entered by the agents, and not by ORANGE, with the origin of these being unknown. It insists that it is not possible to consider the SIM card as personal data, nor has this been justified by this Agency. Furthermore, in the event that such consideration could be maintained, the processing of data would not be attributable to ORANGE, but would have been carried out by a criminal working for a data processor of ORANGE, acting against the instructions and interests of ORANGE. It wishes to remind that the agents did not access the mobile phone of the complainant, nor the information it may contain, as long as the mobile phone was in the possession of the complainant.

ORANGE insists that the SIM card does not contain the data of the mobile phone, and that a duplicate of the SIM card does not allow a third party access to the applications of the holder.

Therefore, it cannot be asserted that there has been an unlawful processing of the complainant's data by ORANGE, due to the absence of intent or fault, and thus, there would be no infringement of Article 6.1 of the GDPR.

Fifth. On the correct implementation of privacy by design and by default.

ORANGE wishes to state that, based on the statements collected in the proposed resolution, privacy by design has indeed been taken into account, based on the documentation submitted, the design of protocols, and the establishment of measures aimed at ensuring compliance with the principles of data protection.

In this regard, the process for issuing duplicate SIM cards involves controls and security measures aimed at ensuring that SIMs are issued at the request of customers and once their identity has been verified, taking into account the protection of the privacy of the data subjects.

However, ORANGE considers that this Agency is attempting to disqualify the documentary evidence solely on the premise of the result that has occurred in a specific case, in which a crime is committed, to cast doubt on the validity of the system, inferring that the set of measures implemented is not in accordance with the principle of privacy by design, as if its compliance depended exclusively on being perfect and infallible, and making subjective observations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/120

At this point, it lists what has been mentioned in the proposed resolution regarding documents 5, 6, and 7.

It adds that ORANGE does have policies aimed at ensuring the application of the principles of data protection in its business processes, regardless of whether a specific reference to privacy guarantees is identified in each of them, since, while they address the associated risks in this matter, it is not the only one taken into account, just as the analyzed criminal risks, or economic or reputational risks are not specified in each of them.

Furthermore, it states that there is no contradiction between the interests of the company and the protection of personal data, and that privacy by design is guaranteed in all cases, not only from a formal point of view, but as an inherent purpose of its daily activity.

In this sense, it would have provided the initial information that is made available for any project in which personal data is processed in order to begin regulating the various activities always from a perspective that safeguards privacy and the protection of personal data. However, for each particular case, the measures deemed appropriate are applied, such as the training of personnel responsible for controlling the processes.

Additionally, it wishes to remind that both the technical and organizational measures and the guarantees provided for by Article 25 of the GDPR are not fixed, nor do they require the implementation of specific measures.

5.1. On the risk analysis for rights and freedoms.

At this point, ORANGE states that it was already provided as document No. 12, in the allegations to the initiation agreement, and that it was evaluated by this Agency in the proposed resolution.

Therefore, ORANGE states that it cannot be denied by this Agency that the risk was not identified, although it is presented by the Risk Committee adding what was provided by various areas.

Moreover, it insists that the consideration of such a level of risk was not made in the year 2023, but was also done in the years 2021 and 2022, providing to substantiate this the Annex Document 1, related to the risk committee, which took place in the year 2022, where it can be visualized:

- the aggregated risk level for the risk "Fraudulent use of Data-3rd parties" was low.
- a second slide is provided with the comparison with the previous year, where that risk was already evaluated concluding that it was low.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
33/120

It adds that this same information for the year 2023 was provided as document no. 12, to highlight that it is the same analysis in different years, and in all cases it was rated as low.

They submit as annex document 2 the minutes of the Local Risk Committee from the year 2022 to demonstrate that the risk was also rated as low.

From the perspective of risk concerning the rights and freedoms of the interested parties, they provide as Annex Document 3 the Risk Analysis for the Rights and Freedoms of the Interested Parties corresponding to the year 2022, when the events occurred, where the risk was identified as low, and which, according to ORANGE, was raised to the Risk Committee.

ORANGE insists that, within the framework of the probability of risk materialization, it was unlikely, because there was no record of such materialization at ORANGE. With the opening of this sanctioning procedure, the risk was reclassified as medium, and currently it is classified as high, and new measures are being implemented to reduce the risk again.

Therefore, it wants to state that it is incorrect to assert that this type of risk has not been analyzed by ORANGE. The evolution of the consideration of this type of risk has been increasing recently, due to the detection of the first case of this type corresponding to this procedure.

ORANGE wants to express that this does not mean that it acts in a corrective rather than preventive manner, but rather that the risk had been classified as low, and therefore, it was not considered necessary to implement additional measures beyond those already in place, given that their effectiveness was supported by the absence of contingencies related to the actions carried out by agents in which there was inappropriate use of their credentials and permissions for illicit purposes. It adds that this remains an isolated incident.

It adds that preventive measures can be identified that this Agency did not take into account in the proposed resolution, which are:

- Legal measures: contract with the franchisee that includes a confidentiality commitment.
- Organizational measures.
- Communication of instructions, such as the informational pill provided to ORANGE Agents.
- Access control and recording of actions executed by users.
- Error management protocol.

ORANGE insists that the risk was identified, evaluated, and proportional measures were implemented for its mitigation, based on the fact that the risk was low, in accordance with the EDPB guidelines.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

34/120

Thus, in accordance with the identified risk, regarding the duplication of the SIM card, the procedure already analyzed in the present sanctioning procedure was developed, and in prevention of possible circumstances in which the (...).

In the case at hand, ORANGE continues, there was no failure in the security measures, but rather the personnel responsible for executing the process decided to act against it. Therefore, it insists that this Agency cannot equate the commission of a crime by agents of the company itself with a supposed lack of implementation of privacy by design from this company.

ORANGE insists that this Agency does not take this situation into account in the proposed resolution. Furthermore, ORANGE adds that, in the case of a duplicate SIM card, there are two opposing risks:

- False positives, a situation in which a malicious third party has requested the duplicate of the SIM card.
- False negatives, a valid identity document that is rejected, resulting in the customer losing access to

their mobile phone service.

Therefore, ORANGE adds, the risk analysis in which the establishment of this measure was considered was not based solely on business, as this Agency stated, but weighed the two aforementioned risks, deciding on this measure from the perspective of privacy by design.

ORANGE refers at this point to the EDPB, which has considered, in its guidelines 5/2022 on the use of facial recognition technology in law enforcement, the agility in management as one with a positive impact for the interested parties themselves, which must be taken into consideration.

It expresses its disagreement with the assertion made in the proposal regarding the fact that the risk had not been anticipated, because it has already been stated that it had indeed been categorized as a low risk, and there was also a visual and in-person verification by the agent, and there is also subsequent control by the Company's Analysis and Risk Group to evaluate whether there was inappropriate use of this possibility.

ORANGE states that, no matter how many controls are established, it is never completely avoidable that a malicious user could carry out an illicit action regarding the information to which they have access.

ORANGE expresses its disagreement with the fact that an isolated incident could have sufficient weight to decree without further ado the general non-compliance with the principle of privacy by design and by default of the company, and justify the sanction.

It states that it is a generic and ambiguous provision, which would not imply the breach of any specific obligation, and insists that it has not been considered.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/120

a threat cannot invalidate the entire compliance system implemented.

Finally, it wishes to express that, regarding the "suspension" of the procedure for the issuance of duplicate SIM cards, this should be understood as a change in the configuration of the process that is generated (...), and that it has occurred as a precautionary measure until this procedure concludes so that it does not condition its development.

In this regard, an expert assessment is being conducted to evaluate the tool, which will be provided later, which has not yet occurred.

Sixth. On the existence of a concurrence of infringements.

ORANGE states that the two infringements are based on the criminal conduct of the agents, which constitutes a case of concurrence of infringements in the administrative pathway.

In this sense, ORANGE understands that what is decisive to determine whether this non-compliance has indeed occurred is the adequacy or inadequacy of the measures implemented. It states that, according to the arguments presented by this Agency, it can be inferred that there is a direct connection between the violations of both articles. It considers that the infringement of Article 6 of the GDPR, that is, the existence of an (alleged) unlawful data processing was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, derived from the absence of (indicated in terms of defense, allegedly) sufficient security measures.

Seventh. On the inadmissibility of objective liability.

ORANGE insists that the proposed resolution is based exclusively on the outcome, without taking into account that the fact occurs due to the criminal and intentional actions of the agents of the ORANGE distributor, who acted as data processors, corrupting the process and the measures stipulated by it. ORANGE understands that the criminal actions of the agents have automatically determined that adequate measures were not adopted, resulting in ORANGE's direct liability arising automatically. Furthermore, it understands that this Agency has determined that a generic type of fraud has occurred without assessing the specific circumstances of this case.

ORANGE believes that this Agency has erred by considering the following points:

- First, the criminals were sales agents of a distributor's point of sale, and not cybercriminals. (page 77 of the proposed resolution)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

36/120

- Second, this Agency does not take into account the evolution of SIM SWAPPING fraud, considering that, in the event of an alleged fraud, the entity is deemed responsible, regardless of the actions of the point of sale agents.

It insists that they had identified the risk, but it was considered low risk, as it had not occurred previously.

ORANGE considers that, regarding payment services regulations, it would be unjustifiably classifying the obligations of both operators and banking entities as identical, since ORANGE cannot be held accountable for the deficiencies and decisions made by the banks.

ORANGE states that, according to this Agency, risks must be based on what is reasonable and technically possible, and considers that, in this case, ORANGE had placed its trust in its distributors. It also believes that human intervention is inevitable.

It adds that this Agency expects ORANGE to foresee each and every threat that may occur, anticipating a result in which the measures are infallible, overlooking threats that are difficult to predict, as would be the case here.

This is why it understands that this Agency would establish an obligation of result, by stating that the commission of a criminal act in the ORANGE environment automatically entails its liability, regardless of the intent employed by the perpetrator, and the level of diligence exercised by ORANGE.

ORANGE states that this Agency has not assessed the jurisprudence presented regarding the inadmissibility of objective liability in the context of the sanctioning administrative procedure.

Therefore, it understands that, since the concurrence of a culpable, intentional, or negligent action by ORANGE has not been proven, it is not appropriate to determine that it has committed an infringement of data protection regulations.

Eighth. On the measures adopted and implemented by ORANGE.

ORANGE considers that it has already listed the measures it had deployed, both prior and subsequently, and proceeds to enumerate them again, so that this Agency can appreciate the constant evaluation and analysis of risks, as well as the measures applied, which were modified as different types of SIM SWAPPING fraud were identified:

1. Measures implemented by ORANGE to prevent fraud resulting from the identity theft of its customer.
- Documentation already provided that is made available to the agents and other personnel capable of carrying out actions at ORANGE.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/120

-additional communications reiterating the action protocols for the issuance of duplicate SIM cards.
-(...).

-ORANGE is part of the Spanish Association for Digitalization and participates in the project "Secure Digital Identity," which aims, among other things, to protect against fraud and cyberattacks and to defend data privacy.

-“SIM Swap service” (...).

2. Measures implemented by ORANGE to prevent fraud arising from the impersonation of ORANGE agents and/or employees.

-implementation of a two-factor identification system, which is currently in the testing phase with certain users.

-project (...).

-traffic control tools, which are used by ORANGE's Risk Analysis Group, and which can generate

alerts in case of possible detections of irregular contracts, and which operate as follows in the case of duplicate SIM cards:

- (...).
- (...).

3. Measures adopted concerning the present case, not covered in the previous sections.

-the risk associated with this type of case has been modified, having a greater impact on the company's protocols and actions.

-cautious suspension has been implemented (...) that occurs in cases like the one that prompted the opening of this sanctioning procedure, in order to determine the appropriate measures to mitigate the identified risks.

In any case, ORANGE wishes to express that it carries out constant monitoring and review of the existing risks related to duplicate SIM cards, that the protocols are updated, and that measures are adopted in accordance with the identified risks, without this allowing for the imposition of a guarantee or requirement of infallibility.

ORANGE states that this Agency has not reviewed this breakdown, which it understands is essential to comprehend the threat and to be able to prevent and mitigate its commission.

It adds that this Agency has previously archived procedures related to SIM Swapping, listing some of these procedures.

Therefore, ORANGE believes that it has demonstrated both its willingness to protect the rights of individuals and the use of an adequate level of diligence, with the existence of a zero-risk being updated and reviewed periodically in accordance with the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, making it impossible to identify a violation of Article 25 of the GDPR.

Ninth. On the lack of proportionality of the proposed sanction.

ORANGE states that it has acted with due diligence in implementing measures in the processes of duplicate SIM cards, but, in the event that this Agency considers that there is such a non-compliance, it understands that the sanction is disproportionate, taking into account the circumstances and content of the infringement, to the extent that it has been committed intentionally by agents of the distributor.

In this regard, it understands that the following aggravating factors used by this Agency have been applied without the circumstances for their consideration being present:

-Nature, severity, and duration of the infringement (art. 83.2.a) GDPR)

ORANGE understands that this aggravating factor is based on the possible commission of fraudulent banking operations, and it is not acceptable that the use of bank accounts, the monetary damages suffered by the victims of fraud, or the manner in which these operations are carried out by banking entities is used as an argument to justify the sanction.

Furthermore, regarding the imposition of the aggravating factor in the infringement of Article 25, the totality of ORANGE's customers is taken into consideration.

ORANGE believes that it is not possible to consider unexamined and undocumented factual assumptions, without being able to extrapolate this commission of a crime to all the processes of duplicate SIM cards of this company.

Likewise, it considers that the "social alarm" generated for this type of practice cannot be classified as an aggravating factor, as it is a criminal activity of organized groups that recruit employees from telecommunications companies.

-every infringement committed by the data controller or processor (art. 83.2.e) GDPR)

ORANGE reiterates its disagreement with the fact that this aggravating factor is used, as the facts that motivated these procedures have nothing to do with the present factual case.

-the link between the business activity of the defendant and the processing of personal data of clients or third parties (art. 83.2.k of the GDPR in relation to article 76.2.b) of the LOPDGDD)

ORANGE understands that, due to its activity, the processing of personal data is necessary, but that, according to Article 83.2.k), this aggravating factor should be applied considering the specific case.

Thus, in no case has it been ORANGE's intention for this case to occur, and it reiterates that the operator has also been harmed. Therefore, it believes that the application of this aggravating factor is

not possible.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/120

- Intentionality or negligence in the infringement.

ORANGE expresses its disagreement with the provisions in the proposal regarding this aggravating factor, to the extent that it concerns an unprecedented situation caused by the commission of a criminal act not attributable to ORANGE.

Furthermore, it considers that this Agency has not taken into account the following mitigating circumstances:

- ORANGE proceeded to block the line when it became aware of the facts. (art. 83.2.c) GDPR).

It understands that ORANGE cannot be held responsible for the economic losses suffered by the claiming party.

- Special categories of data have not been processed (art. 83.2.g)

- The degree of cooperation of ORANGE with this Agency. (art. 83.2.f)

- Adherence to codes of conduct under Article 40 or certification mechanisms approved under Article 42 (art. 83.2.j)

- The nonexistent benefit obtained by ORANGE. (art. 83.2.k), stating that, in any case, it has been harmed.

Finally, ORANGE wishes to record and demonstrate that the measures in place at the time of the infringement complied with the norms, guidelines, standards, and recommendations to address the risks, which were adequate and appropriate considering the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of individuals.

Additionally, it wishes to convey to the Agency its acceptance of any type of proposal or recommendation regarding compliance with the regulations.

For all these reasons, it requests the filing of the present procedure, and subsidiarily that a warning be issued, and ultimately that the proposed sanction be moderated or adjusted.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/120

FIRST: It is recorded that, on December 15, 2022, a duplicate of the SIM card owned by the claiming party was issued without their request, at the establishment owned by "TOWER PHONE, S.L.," located at ***ADDRESS.1 in Madrid, which acts as a franchise of ORANGE, as stated in the franchise contract dated April 1, 2022.

Thus, in the franchise contract dated April 1, 2022, provided by ORANGE with the entity TOWER PHONE S.L.U., it can be observed:

"Background:

I. That it is part of the activity and corporate purpose of ORANGE to provide and market various telecommunications services, electronic communications, and information society services.

II. That ORANGE ESPAGNE S.L.U., in the development of its corporate purpose, markets its services and has established its commercial network in commercial traffic under the brands and other distinctive signs that are its own or whose brand uses it is authorized to assign, being interested in designating franchisees, (...)"

(...)

IV. (...).

V. (...).

(...).

Likewise, in the object of the contract, it can be observed:

“(…).

(…)”

SECOND: ORANGE is responsible for the data processing referred to in the present procedure, since according to the definition of Article 4.7 of the GDPR, it is the one who determines the purpose and means of the processing carried out.

In clause Twenty-Second, relating to the processing of personal data, it is noted:

“Under this contract, the FRANCHISEE, in its capacity as data processor, will carry out the processing of personal data necessary for the correct provision of the services subject to this contract.”

THIRD: It is recorded that, to request the duplicate of the SIM card, ORANGE has implemented an automatic system for validating the identity document, but that, in some cases (...) of the person requesting the duplicate of said SIM card, (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/120

FOURTH: ORANGE has stated that, at the time of contracting the duplicate SIM card for the claimant, “the protocol established by this company was followed by passing an identity document through the verification system (...).”

“(…)”

Regarding the issue of whether the system of (...) verifies the correspondence of the document number and the name of the document holder with the data of the applicant for the procedure, (...). Therefore, as a general rule, the system (...) does validate the name of the identity document holder with the information of the applicant for the procedure, (...).”

FIFTH: (...).

SIXTH: ORANGE has acknowledged that the duplicate of the claimant's SIM card was produced due to an irregularity by agents working in the store where the duplicate was made, (...).

SEVENTH: ORANGE has stated in its writing dated March 30, 2023, that it has given its employees the following instructions on how to proceed with the use of the DNI validation system, which are as follows:

- It is mandatory not to make a change or duplicate of a SIM card for a person other than the holder (or administrator or authorized person of the company as recorded in the systems). The person who is going to make a duplicate must provide a valid identity document (according to protocol), which will always be validated. (...)
- If at the time of the request the system is not functioning, the agent must open an incident and ask the customer to return the next day.
- The agent managing a duplicate request must request the identity documentation, (...).
- In cases where the identity document (...).

EIGHTH: ORANGE has stated in its written allegations dated December 21, 2023, that it has implemented the following measures in cases of requests for duplicate SIM cards:

- Since August 12, 2022 (...).
- Since August 12, 2022 (...).
- Since April 2021, ORANGE has been limiting the channels from which a duplicate SIM card can be requested (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

NINTH: ORANGE has stated in its response to the transfer of the complaint, dated January 30, 2023, as well as in its response to the request, dated March 30, 2023, and in its allegations to the initiation agreement of the present sanctioning file, dated December 21, 2023, that it would have adopted the following measures to prevent the commission of frauds arising from the impersonation of agents and/or employees of ORANGE:

- On December 28, 2022, and prior to the notification of this request, a mandatory training module was provided from the School of Sales Representatives to the entire distribution channel at the points of sale in order to assist and raise awareness among the sales teams about the risk of recruiting sales representatives to physically make duplicates from the points of sale."
- A training module would have been disseminated to the entire distribution channel with the aim of raising awareness among workers about the existing issues and the obligation to comply with all customer identification procedures and policies.
- The implementation of a double identification factor would have been initiated, with its pilot project already implemented and currently in the testing phase.
- A project would have been launched (...).
- A tool from the Risk Analysis Group would have been implemented, which allows alerts to be generated in case of possible detection of irregular contracts, and which in the case of duplicate SIM cards would act as follows:

(...).

(...).

- Since December 14, 2022, as stated by ORANGE in its allegations to the initiation agreement of the present sanctioning file, it would have proceeded with the precautionary suspension of the option that allows point of sale agents, (...), thus being unable to attend to any type of exception.

TENTH: Regarding the case that has motivated this sanctioning file, ORANGE has stated in its allegations to the present sanctioning file dated December 21, 2023, that it would have carried out the following actions:

- A complaint has been filed against the responsible agents.
- The involved agents were terminated from the establishment.

ELEVENTH: It is noted that, in the complaint filed by the entity TOWER PHONE, S.L., on January 12, 2023, the concept of SIM SWAPPING is defined as follows:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

"SIM Swapping is a cyberattack that consists of impersonating a person before their telecommunications service provider and requesting a duplicate of the SIM card of their mobile phone in order to access their online banking and operate with it, receiving SMS messages with the confirmation code for banking transactions on that new SIM, proceeding to divert money from the bank account of the impersonated person to another account owned by the criminals. The victim, as happens in the present case, only becomes aware of the situation when they lose coverage on their mobile phone, and no matter how much they restart the device or try to find coverage, they cannot achieve it since, when the new duplicated SIM requested by the cybercriminals becomes operational, the SIM inside the victim's phone stops working."

TWELFTH: It is recorded that in the complaint filed by TOWER PHONE S.L., it states that "a complaint is filed against B.B.B. with NIE: (...) for possible crime of:

(...)

It is also recorded that when discussing the concept of SIM Swapping, it states:

"First of all, it is important to explain what the facts reported here (SIM Swapping) carried out by the accused C.C.C. consist of, at least on the days 14, 17, and 21 of December 2022 at their workplace, the Orange point of sale located at (...) in Madrid (**ADDRESS.2)"

(...)

In the fourth section of the complaint, relating to the Reported Facts, it states:

"Recently, my represented party has become aware of the facts that we will detail below, which have been duly verified and contrasted with the respective internal departments of the company, through the issuance of a report and attributed to the accused.

An Internal Investigation Report is attached with its accompanying documents prepared and signed by the Store Manager located at ***ADDRESS.1 Madrid, owned by Tower Phone, S.L., (...). The annexes of the internal investigation report are as follows:

Annex 1: Justifying documentation of B.B.B.'s work schedule on October 6, 2022 (first impersonation).

Annex 2: Justifying documentation of B.B.B.'s work schedule on October 7, 2022 (second impersonation).

Annex 3: Justifying documentation of B.B.B.'s work schedule on October 13, 2022 (third impersonation).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/120

Annex 4: Justifying documentation of B.B.B.'s work schedule on November 3, 2022 (fourth impersonation).

Annex 5: Justifying documentation of B.B.B.'s work schedule on November 15, 2022 (fifth impersonation).

FIRST, my represented party became aware of the facts reported here for the first time on October 20, 2022, when they went to the ORANGE store located at ***ADDRESS.1 in Madrid (...) alerting that a few days ago they came to the store and that on the same day they supposedly received a call from ORANGE. The inquiry at the store was about an unpaid bill, and the call corresponded with the visit to the store and the unpaid bill to collect it by bank card. After several failed attempts with their card, a boy contacted the client (...) and told them that since they were from the same area, it was a scam, that they should not pay attention, and that such customer information was received through the stores. From the very first moment, the client directly accused B.B.B. (...) to which an email was sent to the supervisor to ensure they were aware of these frauds. (...)

(...)

SECOND, on November 16, 2022, the manager of the ORANGE store (located at ***ADDRESS.1) received a call from the ORANGE store in ***LOCALITY.1, Madrid, indicating that on the previous day, November 15, 2022, at 20:45 hours, a duplicate card had been made for the client A.A.A. using the code of the corresponding point of sale for the ORANGE store located at ***ADDRESS.1 in Madrid. In light of these facts, the manager of the ORANGE store at ***ADDRESS.1 asked the store staff if they had made a SIM card change the previous day since it did not appear as billed in our billing system, and it was confirmed that the SIM card that had been used was in the store's stock. The staff commented that they had not done it and had no record of it. Since there are cameras in the store, the video from the day of the events (November 15, 2023) was reviewed, where it was observed that at the time the card duplication was taking place, (...) and B.B.B. was at the cash register computer apparently talking on the phone with a headset.

(...)

Given the seriousness of the facts, all the information was sent to the ORANGE supervisor that same day, and an informative email about what happened was sent.

(...)

Subsequently, on November 18, a response was received from the telecommunications company ORANGE informing this party that for this procedure, documentation and the signature of another person had been used (...). Likewise, this party was confirmed that this person came to request a duplicate card the day before the fraud with the employee B.B.B. at the ORANGE store located at ***ADDRESS.1, and it is correctly billed.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
45/120

(...)

It is important to note that when a duplicate card is issued, the one currently in the system is canceled and replaced with a new one, invalidating the previous card at the same moment. Duplicates are usually issued when the current card, for example, is not functioning, the customer has lost their mobile phone, or it has been stolen. THE PROTOCOL THAT MUST BE FOLLOWED TO ISSUE A DUPLICATE is with the customer present in the store and with their original and valid document, as we must scan the document for validation and ensure that it is the account holder who is making the change of the SIM card.

(...)

THIRDLY, and as a consequence of the fraud previously detailed, this party requests from ORANGE all available information to proceed with the suspension or dismissal of the suspect B.B.B. from the store, and for this, this party needed their Cybersecurity department to confirm how many duplicates have been made from the store at ***ADDRESS.1 that are fraudulent, the times of such, and the IP that made that duplicate. This IP is particularly relevant as it ensures that it was made from the store, and not from another external or unauthorized computer.

This party received confirmation from ORANGE indicating the following duplicates, all of which were made with the IP (...) corresponding to the computers of the Orange Store ***ADDRESS.1:

1. FRAUDULENT DUPLICATE SIM CARD (SIM SWAPPING) ON DATE 06-10-2022, 20:42 HOURS AT THE POINT OF SALE ORANGE STORE ***ADDRESS.1, MADRID.

On October 6, 2022, at 20:42 hours, a duplicate of the SIM card (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID (...). According to the geolocation of the IMEIs of the devices used for the duplicate of the SIM, the impersonation occurred at the ORANGE store ***ADDRESS.1 in Madrid owned by my client. To certify this geolocation, this party will request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store ***ADDRESS.1 in Madrid owned by my client, the time sheets attached in the internal investigation report (Annex 1) show that during the time frame (06/10/2022) at 20:42 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that B.B.B. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

46/120

2. FRAUDULENT DUPLICATE SIM CARD (SIM SWAPPING) ON DATE 07-10-2022, 20:36 HOURS AT THE POINT OF SALE ORANGE STORE ***ADDRESS.1, MADRID.

On October 7, 2022, at 20:36 hours, a duplicate of the card with SIM number (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID (...). According to the geolocation of the IMEIs of the devices used for the duplicate of the SIM card, the impersonation occurred at the ORANGE store ***ADDRESS.1 in Madrid owned by my client. To certify this geolocation, this party will request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store ***ADDRESS.1 in Madrid owned by my client, the time sheets attached in the internal investigation report (Annex 2) show that during the time frame (07/10/2022) at 20:36 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that B.B.B. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

3. FRAUDULENT DUPLICATE SIM CARD (SIM SWAPPING) ON DATE 13-10-2022, 18:43 HOURS AT THE POINT OF SALE ORANGE STORE ***ADDRESS.1, MADRID.

On October 13, 2022, at 18:43 hours, a duplicate of the card with SIM number (...), IMSI number (...), belonging to the mobile number (...) owned by customer (...) with ID (...). According to the geolocation of the IMEIs of the devices used for the duplicate of the SIM, the impersonation occurred at the ORANGE store ***ADDRESS.1 in Madrid owned by my client. To certify this geolocation, this party will request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store ***ADDRESS.1 in Madrid owned by my client, the time sheets attached in the internal investigation report (Annex 3) show that during the time frame (13/10/2022) at 18:43 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that B.B.B. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

4. FRAUDULENT DUPLICATE SIM CARD (SIM SWAPPING) ON DATE 03-11-22, 20:16 HOURS AT THE POINT OF SALE ORANGE STORE ***ADDRESS.1, MADRID.

On November 3, 2022, at 20:16 hours, a duplicate of the card with SIM number (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID (...). According to the geolocation of the IMEIs of the devices used for the duplicate of the SIM, the impersonation occurred at the ORANGE store ***ADDRESS.1 in Madrid owned by my client.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/120

produced at the Orange store ***ADDRESS.1 in Madrid owned by my represented party. To substantiate this geolocation, this party will request the commercializer Orange to provide said report. It is worth noting that this fraud was reported by Orange to my represented party on November 21, 2022.

(...)

Once it has been corroborated that the duplicate was carried out at the Orange store ***ADDRESS.1 in Madrid owned by my represented party, the time sheets attached in the internal investigation report (Annex 4) show that during the time slot (03/11/2022) at 20:16 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that B.B.B. was at his corresponding workplace (point of sale) on the dates and times when the duplicate occurred.

(...)

5. FRAUD DUPLICATE SIM CARD (SIM SWAPPING) ON DATE 15-11-2022, 20:16 HOURS AT THE POINT OF SALE ORANGE STORE ***ADDRESS.1, MADRID.

On November 15, 2022, at 20:46 hours, a duplicate of the card with SIM Number (...), IMSI Number: (...) and belonging to the mobile number (...), owned by the Orange customer (...) with ID: (...).

According to the geolocation of the IMEIs of the devices used for the SIM duplication, the impersonation occurred at the Orange store ***ADDRESS.1 in Madrid owned by my represented party. To substantiate this geolocation, this party will request the commercializer Orange to provide said report.

Once it has been corroborated that the duplicate was carried out at the Orange store ***ADDRESS.1 in Madrid owned by my represented party, the time sheets attached in the internal investigation report (Annex 5) show that during the time slot (15/11/2022) at 20:46 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that B.B.B. was at his corresponding workplace (point of sale) on the dates and times when the duplicate occurred.

(...)

“SIXTH,- The narrated facts may constitute a:

- POSSIBLE CRIME OF FRAUD USING ELECTRONIC MEANS. (248.2 CP)

- AND/OR POSSIBLE CRIME OF THEFT (234 CP) AND/OR POSSIBLE UNLAWFUL

APPROPRIATION (235 CP AND FOLLOWING)

- AND/OR POSSIBLE IDENTITY THEFT WITH USURPATION OF CIVIL STATUS (401 CP).
- AND/OR POSSIBLE CRIME OF COMPUTER INTRUSION AND INTERCEPTION OF COMPUTER DATA TRANSMISSIONS (197 BIS CP)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/120

(...)

THIRTEENTH: ORANGE has presented in its written allegations to the initiation agreement of the present sanctioning file, dated December 21, 2023, a “GDPR REPORT. AUDIT OPINION.

APPLICATION OF PRIVACY PRINCIPLES BY DESIGN AND BY DEFAULT,” dated December 18, 2023, and in the conclusions, it can be observed:

“(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/120

FOURTEENTH: ORANGE has presented in its written allegations to the initiation agreement of the present sanctioning file, a document titled “Procedure. Data Protection by Design and by Default,” with an initial version dated 04/04/2018, and in its version 2.0 dated November 18, 2019, it can be observed in section 4:

“4. Data Protection by Design

In compliance with what is stated in the Privacy by Design Guide published by the AEPD, ORANGE has the obligation to adopt privacy design strategies aimed at applying the appropriate technical and organizational measures from the first phase of development of an information system or a new project or service that involves data processing, and throughout its execution, as well as to verify and manage control over the collection, use, and disclosure of personal data processed from the first phase of personal data processing.

(…):

- (...).

- (...).
- (...).
- (...).

(...)

5. Data protection by default.

(...).

(...):

- (...).
- (...).
- (...).
- (...).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/120

(...).

6. Implementation of appropriate measures

(...).

(...).

(...).

(...).

(...):

- (...).
- (...).
- (...).
- (...).
- (...).
- (...).

(...)

7. Verification of compliance

(...):

- (...).
- (...).
- (...).
- (...).
- (...).

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/120

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for the Protection of Data is competent to initiate and resolve this procedure. Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this

organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since ORANGE collects and retains, among others, the following personal data of individuals: name and surname, date of birth, email address, and banking data, among other processing activities.

ORANGE carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

It is necessary to point out that Article 4.1 of the GDPR defines: "personal data" as "any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person."

In this regard, it is important to clarify that within the mobile terminal, the SIM card is inserted. It is a smart card, in a physical format and of small dimensions, which contains a chip that stores the service key of the subscriber used to identify themselves to the network, that is, the customer's mobile line number MSISDN (Mobile Station Integrated Services Digital Network), as well as the subscriber's personal identification number IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the call and message logs.

On the other hand, the issuance of a duplicate SIM card involves the processing of the personal data of its holder, as any person whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a phone number (Article 4.1 of the GDPR), will be considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number, in turn, identifies its holder. In this sense, the Judgment of the CJEU in Case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person.' This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally and uniquely identifies the subscriber on the network are personal data, and their processing must comply with data protection regulations.

Article 6 of the GDPR regulates the lawfulness of processing.

Additionally, Article 25 of the GDPR regulates data protection by design and by default.

III

Response to the Allegations Against the Initiation Agreement

In response to the allegations presented by the accused entity against the initiation agreement, the following should be noted:

First: Existence of Criminal Prejudice.

ORANGE makes this statement as a lawsuit has been filed against the agents who acted criminally in issuing the duplicate SIM card, and since these facts are the basis of a criminal investigation in which it is listed as the harmed party, it would be subject to the principle of criminal prejudice provided for in Article 10 of Organic Law 6/1985, on the Judiciary.

Consequently, it believes that the matter should be resolved in the criminal jurisdiction before any pronouncement is made in the administrative jurisdiction, proceeding with the suspension of this sanctioning procedure, in accordance with the provisions of Article 22.1(g) of Law 39/2015, on the Common Administrative Procedure of Public Administrations, as, according to Article 77.4 of the aforementioned Law 39/2015, in sanctioning procedures, the facts established as proven by final criminal judicial resolutions will bind Public Administrations regarding the sanctioning procedures they process. Thus, ORANGE understands that in this case, there is a triple identity of subject, fact, and

foundation:

Regarding the subject, the authorship of the facts has been established in both procedures by the commercial agents.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/120

Regarding the fact, there would be agreement as it concerns the fraudulent issuance of a duplicate SIM card.

Regarding the basis, there would be a sanctioning on two occasions for the illegitimate and fraudulent conduct of the agents, contrary to the protocols and procedures established by ORANGE.

In relation to this issue, this Agency considers it necessary to point out that, in the present sanctioning file, however, there is no triple identity required to apply Article 77.4 of Law 39/2015 concerning subject, fact, and basis between the administrative infringement being assessed and the possible criminal infringements that could arise from the complaint filed before the judicial body mentioned by ORANGE, to the extent that the infringing subject is not the same.

Thus, ORANGE is the responsible subject in the present sanctioning procedure, while the criminally responsible party would be the employee who proceeded with the duplication of the SIM card, as stated in the complaint submitted by ORANGE in its written allegations.

In this regard, the Judgment of the National Court of 27/04/2012 (rec. 78/2010) is very enlightening, in which the Court states in its Second Legal Basis the following in response to the appellant's claim that the AEPD has violated Article 7 of R.D. 1398/1993 (a regulation that was in force until the entry into force of the LPACAP):

"In this sense, Article 7 of Royal Decree 1398/1993, of August 4, on the procedure for exercising the sanctioning power, only provides for the suspension of the administrative procedure when the effective and real existence of a criminal procedure is verified, if it is considered that there is identity of subject, fact, and legal basis between the administrative infringement and the criminal infringement that may correspond.

However, for the concurrence of a criminal prejudiciality, it is required that it directly conditions the decision to be made or that it is essential for resolution, conditions that do not occur in the case examined, in which there is a separation between the facts for which a sanction is imposed in the resolution now appealed and those that the appellant invokes as possible criminal offenses. Thus, even if criminal proceedings had been initiated in this case, and for the facts now in dispute, against the distributing company, the truth is that both the sanctioning conduct and the protected legal interest are different in each avenue (contentious-administrative and criminal). In the criminal sphere, the protected legal interest is a possible documentary falsification and fraud, while in the administrative sphere, it is the right to dispose of one's personal data by its owner, which is why such an objection from the defendant must be rejected."

Therefore, the issue raised by ORANGE cannot prosper and must be rejected.

Second: On the supposed fact.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/120

ORANGE states that the issuance of a duplicate SIM card involves the issuance of a SIM card without personal information, and that by itself it does not allow access to banking or financial information.

In relation to this matter, and as already included in the agreement initiating this sanctioning procedure, the SIM card is a card that is inserted into the mobile terminal. It is a smart card, in a physical format and of small dimensions, which contains a chip that stores the service key of the subscriber used to identify themselves to the network, namely, the customer's mobile line number MSISDN (Mobile Station Integrated Services Digital Network), as well as the subscriber's personal

identification number IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the phone directory or call and message logs.

Furthermore, the issuance of a duplicate SIM card involves the processing of the personal data of its holder since any person whose identity can be determined, directly or indirectly, particularly by means of an identifier (Article 4.1 of the GDPR), is considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number in turn identifies its holder. In this regard, the judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971 states: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person.' This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must comply with data protection regulations.

In this regard, the judgment of the National Court of February 8, 2024, states:

"We must start from the premise that the issuance of a duplicate SIM card involves the processing of the personal data of its holder since, according to Article 4.1 of the GDPR, any person whose identity can be determined, directly or indirectly, particularly by means of an identifier, is considered an identifiable natural person. Well, within the mobile terminal, the SIM card is inserted. It is a smart card in a physical format and of small dimensions, which contains a chip that stores the service key of the subscriber used to identify themselves to the network, namely, the customer's mobile line number MSISDN (Mobile Station Integrated Services Digital Network) as well as the subscriber's personal identification number IMSI (International Mobile Subscriber Identity), but it can also provide..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/120

to provide other types of data such as information about the telephone directory or calls and messages.

And as highlighted in the contested resolution, since 2007, in Spain, in accordance with the Single Additional Provision of Law 25/2007, of October 18, on the retention of data related to electronic communications and public communications networks, it is required that the holders of all SIM cards, whether prepaid or contract, be duly identified and registered. Therefore, when obtaining a duplicate of the SIM card, the person requesting it must also identify themselves and their identity must match that of the holder."

Furthermore, the Judgment of the National Court dated February 9, 2023, also states the following:

"Well, the SIM card is a smart card that is inserted into the mobile terminal, which contains a chip that stores the subscriber's service key used to identify themselves to the network.

Thus, the Attorney General's Office indicates, in a report from July 2016, cited by the contested resolution: "according to European standards related to digital cellular telecommunications systems, established by the European Telecommunications Standards Institute (ETSI), a fully operational mobile cellular communications device, colloquially referred to as a "Mobile Phone," materially consists of two essential elements. First, the terminal (...). Secondly, the user identification module, better known as the "SIM card" (Subscriber Identity Module). This SIM card is interchangeable among the different mobile terminals available on the market and contains its digital chip the necessary information to identify and authenticate the subscriber, included in the International Mobile Subscriber Identity (IMSI), which unequivocally identifies the subscriber on the cellular network. Without a valid IMSI, telephone services will not be accessible, except in the case of an emergency call."

Therefore, the IMSI is the identification code in the cellular communications network and is fundamental for identifying the subscriber, and as it is stored on the SIM card, whoever has that card (the impersonator) has the stored IMSI. Furthermore, as soon as the impersonator inserts the SIM into a terminal and turns it on, the IMSI will be accessed and exchanged with the network.

In this regard, insofar as the IMSI installed on the SIM card allows for the singularization of an individual and therefore their identification, it must be considered as personal data, according to Article 4 of the GDPR, which defines it as “any information relating to an identified or identifiable natural person (the data subject); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.”

That is to say, the improper issuance of a mobile phone SIM card of a person to a third party who impersonates their identity allows that third party to access the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
56/120

confidential information stored on said card and to the line of the legitimate holder of the SIM card, resulting in a clear loss of confidentiality as the data is transmitted to a third party unlawfully.

Please note that in Spain since 2007, by virtue of the Single Provision of Law 25/2007, of October 18, it is required that the holders of all SIM cards be duly identified and registered. This is important because the identification of the subscriber will be essential to activate the SIM card, which will mean that when obtaining a duplicate of it, the person requesting it must identify themselves and their identity must match that of the holder.

In summary, both the personal data (name, surname, and ID number) processed to issue a duplicate of the SIM card, as well as the SIM card itself, which unequivocally identifies the subscriber on the network, are personal data...

In this regard, concerning the fact of granting the duplicate SIM card the ability to allow the execution of banking operations, it should be noted that ORANGE itself, when filing the complaint against the agent who made the duplicate SIM card that has led to the opening of this sanctioning file, has defined the concept of SIM SWAPPING as follows:

“SIM Swapping is a cyberattack that consists of impersonating a person's identity before their telecommunications service provider and requesting a duplicate of the SIM card of their mobile phone in order to access their online banking and operate with it, receiving SMS with the confirmation code for banking operations on that new SIM, proceeding to divert money from the bank account of the impersonated person to another account owned by the criminals.

The victim, as happens in the present case, only becomes aware of the situation when they lose coverage on their mobile phone, and no matter how much they restart the device or try to find coverage, they cannot achieve it since, when the new duplicated SIM requested by the cybercriminals comes into operation, the SIM that is in the victim's phone stops functioning.”

In this sense, ORANGE itself confirms the concept of SIM Swapping, which aims to access online banking, receiving SMS with the confirmation code for banking operations on the new SIM, and proceeding to divert money from the bank account of the impersonated person to another account owned by the criminals. Therefore, in this aspect, there is no doubt about the concept of SIM Swapping and the reasons why duplicates of SIM cards are requested.

Furthermore, in the present case, regarding the infringement of Article 6 of the GDPR, what is being analyzed is the issuance of a duplicate SIM card owned by the claimant and without their consent, in a store owned by ORANGE.

Regarding the infringement of Article 25 of the GDPR, ORANGE, for the establishment of appropriate measures to the risk, must evaluate the possible risks to the rights and freedoms of individuals, among which is that customers

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
57/120

suffer the well-known SIM Swapping attack through the fraudulent acquisition of a duplicate of their SIM card, which leads to the consequent loss of control over their personal data and possible financial losses. All of this is independent of the liability that financial entities may incur if they acted with a lack of diligence.

On the other hand, ORANGE also refers to the fact that, in the initial agreement, erroneous associations are made to aggravate the alleged facts by granting the duplicate SIM card the ability to allow the commission of banking operations, omitting the prior step whereby the wrongdoers must obtain and be able to use the banking credentials of the claimant in order to identify themselves and carry out identity theft before the financial entity.

It adds that this AEPD does not mention the role played by financial entities in these cases, and there is no record that sanctioning procedures have been initiated against them.

Regarding the responsibility of financial entities, it should be noted that Directive PSD2 applies to payment services provided within the Union (Article 2), and not to ORANGE, but it is also true that the issuance of a duplicate SIM card in favor of a third party who is not the line holder provides impersonators with control over the telephone line, and therefore, over the SMS directed to the phone linked to the initial SIM card, thus allowing access to know the authentication code of the transaction. According to Article 4.30 of the Directive, "strong authentication" is based on the use of two or more elements categorized as knowledge (something only the user knows), possession (something only the user possesses), and inherence (something that is the user). These elements or factors are independent of each other and, therefore, the breach of one does not compromise the reliability of the others.

The rationale is very simple: the more elements there are to verify the user's identity, the more secure the transaction is.

In these cases, the impersonator must first enter the username and password in the application or on the website of the payment service provider or online banking. Secondly, to complete the transaction or electronic management they wish to carry out, the impersonator will normally receive, via SMS, an alphanumeric verification code on the mobile phone linked to that profile. This code has a limited temporary validity and is for one-time use only, meaning it is generated solely for that specific transaction and for a limited time.

Once the verification code is entered, the transaction would be carried out and completed. It is assumed that only the user has the mobile device in their possession (this would be the "something they have"), so by receiving the verification code via SMS on that mobile phone, their identity would be doubly authenticated. Therefore, it would not be sufficient for impersonators to commit fraud by merely knowing the username and password with which the victim identifies themselves; it will also be necessary for them to intercept that confirmation code. Consequently, to carry out an unauthorized transfer, transaction, or purchase, that is, to execute the cyber fraud, the cybercriminal must illegitimately access the codes of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/120

Verification associated with each of these operations sent by the banking entity via SMS, and the most common way to do this is through obtaining a duplicate of the SIM card.

Therefore, it is necessary to carry out two completely different but complementary actions.

First, access data to the online banking or payment provider owned by the person to be defrauded must be obtained, if we focus on the search for asset enrichment.

And, second, a duplicate of the SIM card owned by the person to be defrauded must be obtained in order to acquire the confirmation SMS that the client will receive on their mobile terminal as two-factor authentication.

Well, in the last of these actions - obtaining the duplicate - is where the facts subject to this procedure have focused, and not on those that occurred in the first phase, which, as is obvious, are outside the responsibility attributed to ORANGE in this procedure.

On the other hand, ORANGE states that the AEPD intends to sanction SIM SWAPPING frauds without addressing or analyzing the specific case of fact, the associated harm, or the derived responsibilities, without taking into account the diligence displayed by ORANGE in its actions and in adopting security measures.

It adds that the AEPD fails to assess the documentation provided, establishing a generic discourse to legitimize a violation of data protection regulations.

However, regarding this issue, it is necessary to refer to the procedural moment in which ORANGE presents these allegations. In this regard, in accordance with the provisions of Article 64 of Law 39/2015, on the Common Administrative Procedure of Public Administrations, referred to the "Agreement to initiate sanctioning procedures," subsection 2 establishes:

"2. The initiation agreement must contain at least:

- a) Identification of the person or persons presumably responsible.
- b) The facts that motivate the initiation of the procedure, its possible qualification, and the sanctions that may correspond, without prejudice to what results from the instruction.
- c) Identification of the instructor and, where appropriate, the secretary of the procedure and the norm that attributes such competence to them, with express indication of the recusal regime for the same.
- d) Competent body for the resolution of the procedure and the norm that attributes such competence to it, indicating the possibility that the presumed responsible party may voluntarily acknowledge their responsibility, with the effects provided for in Article 85.
- e) Provisional measures that have been agreed upon by the competent body to initiate the sanctioning procedure, without prejudice to those that may be adopted during it in accordance with Article 56.
- f) Indication of the right to submit allegations and to be heard in the procedure and the deadlines for exercising this right, as well as an indication that, in the event of not submitting allegations within the established period regarding the content of the initiation agreement, it may be considered a proposal for resolution when it contains a precise pronouncement regarding the attributed responsibility."

Therefore, the initiation agreement of the present sanctioning procedure contains all the pronouncements required by the applicable regulations.

Without prejudice to the above, the allegation raised by ORANGE cannot be taken into account, insofar as the case of fact is indeed contemplated and assessed when determining the sanction associated with the violations of Articles 6 and 25 of the GDPR, in subsection a) of Article 83 of the GDPR.

Regarding ORANGE's diligence, it should be noted that this aspect has been assessed as an aggravating factor in the violation of Article 25 of the GDPR, so it has been analyzed. In relation to the measures adopted subsequently, it should be noted that they are positively assessed, but do not determine that a violation of Article 25 of the GDPR has not occurred.

Finally, the assertion made by ORANGE that this Agency uses a generic discourse, or that the documentation presented is not assessed, cannot be taken into account, as can be observed in this document and in the large number of proven facts.

Third: On the victim role of ORANGE. On the Modus Operandi.

ORANGE, with this allegation, highlights that it is about the issuance of a duplicate SIM card carried out differently from other cases, in that it was done by two sales representatives of the company, who were acting, consequently, on behalf of ORANGE.

Before continuing with the rest of the argument presented by ORANGE, this AEPD wishes to state that the complaint filed before the Investigating Court is directed against B.B.B., for possible crime of:

- possible crime of fraud using electronic means (238.2 CP)
- and/or possible crime of theft (234 CP) and/or possible misappropriation (235 CP and following)
- and/or possible identity theft with usurpation of civil status (401 CP)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/120

- y/o possible crime of computer intrusion and interception of data transmissions (Article 197 bis of the

Penal Code)

- any other that may be appreciated from the instruction of the present case.

In the facts of the complaint presented, it is evident that the accused began working at the workplace located at ***ADDRESS.1 in Madrid on July 12, 2021. The accused worked until December 11, 2022.

Furthermore, in Fact Four of the complaint, which discusses the reported events, there are up to 5 impersonations carried out by the employee of ORANGE at ***ADDRESS.1 in Madrid.

On the other hand, in Fact Three of the complaint, the concept of SIM SWAPPING is discussed as follows:

"First of all, it is important to explain what the reported events (SIM Swapping) carried out by the accused C.C.C. consist of, at least on the days of November 14, 17, and 21, 2022, at his workplace, the ORANGE point of sale located at (...) (**ADDRESS.2)."

Therefore, although in its allegations ORANGE speaks of two workers from the same store, it is clearly observed that two workers from two different stores have been involved in a case like the one reported by the claimant. Additionally, considering the content of the complaint, in the ORANGE store located at ***ADDRESS.1, 5 individuals were affected, while in the store located at (...) ***ADDRESS.2, 3 people were affected.

Once this clarification is made, in the sense that it was not two workers from the same store who acted incorrectly, but rather workers providing their services in two different stores, and that, from the content of the complaint presented by ORANGE before the Investigating Court, it is clearly deduced that at least 8 people were affected, the statements of ORANGE regarding the impossibility of requiring it to have the total capacity to detect and thwart such criminal acts must fall.

In this regard, the action that has determined that an event such as the one reported has occurred is due to the fact that the procedure that ORANGE had implemented for duplicating a SIM card, (...).

This is explained by ORANGE in its written allegations to the initiation agreement, dated December 21, 2023, submitted to this Agency, in such a way that, as ORANGE expresses, "in the case at hand, ORANGE agents used (...), which is why, when entering it into the system of (...). Thus, for this type of documentation reading errors, ORANGE's Protocol establishes that, although a notice must be generated to the Risk Analysis Group, it allows commercial agents for specified cases (...). This is due to the necessary opening of said...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

61/120

manual operation within an absolutely automated system that must allow for the commercial act (...).".

This is why in the present sanctioning procedure, the infringement of Article 25 of the GDPR has been attributed, as it states that the data controller, taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, must apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

This article imposes an obligation to design internal procedures at the time of determining the means of processing and to apply those procedures at the time of processing, to effectively ensure compliance with data protection requirements.

ORANGE, when communicating the procedure it has implemented for the issuance of duplicate SIM cards, has informed that there are cases in which it can proceed to (...).

The principle of data protection by design imposes that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all the elements that

make up the processing, for the purpose of effectively applying the principles of data protection, integrating the necessary safeguards in the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects.

With the system that ORANGE had implemented, as stated in its written submissions to the initiation agreement of the present sanctioning procedure, dated December 21, 2023, the agents could use (...) that may arise from the delivery of a valid SIM card to a third party without the consent of its owner. Thus, according to ORANGE, by introducing the agents (...). For this type of errors, they state, the ORANGE Protocol establishes that, although a notice must be generated to the Risk Analysis Group, it allows commercial agents for cases (...). According to ORANGE, this is due to the necessary opening of such manual operation within an absolutely automated system that must allow (...).

In this context, ORANGE articulated a protocol that had as its main objective the execution of the commercial act, but that did not contemplate the risk of issuing and delivering a SIM card to a person other than its owner. The notice to the Risk Analysis Group is manifestly ineffective, as it did not succeed in detecting the impersonation, at least in the cases known to this Agency through the present procedure.

Therefore, from the design of the processing, there were no measures from Article 25 of the GDPR to verify that the information entered was not erroneous, and to check that the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/120

Application for duplicate SIM card was being made by the line holder to whom the delivery was also being made.

This implies that ORANGE had not adequately identified and analyzed the risks that a manual process for duplicating SIM cards entails for the rights and freedoms of individuals, nor had it anticipated or applied appropriate technical and organizational measures from the design stage to effectively implement the data protection principles required by Article 25 of the GDPR.

The fundamental right to data protection also includes that data controllers integrate data protection into the design of personal data processing, from its inception and throughout the entire processing cycle, establishing appropriate policies for compliance with this principle and the protection of individuals' rights. This is precisely what ORANGE failed to do and what is being questioned in this sanctioning procedure, as the mechanism that ORANGE had in place did not even foresee the obligation to issue duplicates of SIM cards by introducing (...), as ORANGE acknowledges in its written allegations.

In any case, despite ORANGE's statements that the agents took advantage of their knowledge of the system to commit a criminal act, in its written allegations, they state that "since December 14, 2022, ORANGE has proceeded to the precautionary suspension of the option that allows point of sale agents to (...)." That is to say, despite all the statements made and the defense of the system they had in place, they decided to suspend the system that allows the issuance of a duplicate SIM card (...).

For all the above reasons, this allegation by ORANGE cannot be taken into account.

Fourth: On the non-existence of a lack of legitimacy in the processing of personal data by ORANGE. ORANGE states that, during the process of duplicating the SIM card that led to the opening of this sanctioning procedure, no personal data of the complaining party was provided to any third party, understanding that the commission of criminal acts by the agents is carried out individually, and in opposition to the obligations imposed by ORANGE, and that it cannot be individually attributed to an action of ORANGE.

In relation to this issue, it is necessary to point out that the conduct of ORANGE employees is not the subject of this sanctioning procedure; rather, it is about verifying whether ORANGE's actions comply with personal data protection regulations. While this procedure originates from fraudulent actions by some ORANGE employees, it is no less true that they acted on behalf of ORANGE and that it was ORANGE that provided a duplicate of a SIM card (which, as previously explained in this procedure, is a personal data in itself) to a person other than the line holder, which constitutes processing of

personal data in the terms of Article 4 of the GDPR, without having legitimacy for it, which would violate Article 6 of the GDPR, as explained in Legal Basis IV of this document.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
63/120

Furthermore, the technical and organizational measures that ORANGE had implemented were not adequate or effective to ensure the rights and freedoms of the data subjects, which is why Article 25 of the GDPR would also be infringed, as explained in Legal Basis VII of this document.

On the other hand, ORANGE reiterates its disagreement with the consideration of the SIM card as personal data, citing the Judgment of the General Court of the European Union (Extended Eighth Chamber) of April 26, 2023, which determined that the classification of an alphanumeric code as personal data cannot be presumed; rather, it is the responsibility of the supervisory authority to justify the ability to relate personal data to a specific individual, and it is not sufficient to assume this merely because it could potentially allow for identification.

ORANGE insists that this Agency has not conducted evidentiary activity and directly presumes that the codes contained in the SIM card allow for the identification of the holder.

This issue has been addressed in section two of the response to these allegations, where the following was stated:

Regarding this matter, and as already included in the initiation agreement of this sanctioning procedure, the SIM card is a card that is inserted into the mobile terminal. It is an intelligent card, in physical format and of small dimensions, that contains a chip in which the service key of the subscriber or user is stored, used for identification before the network, that is, the mobile phone line number of the customer MSISDN (Mobile Station Integrated Services Digital Network), as well as the personal identification number of the subscriber IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the phone book or call and message logs. Moreover, the issuance of a duplicate SIM card involves the processing of the personal data of its holder since any person whose identity can be determined, directly or indirectly, particularly by means of an identifier (Article 4.1 of the GDPR), is considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number, in turn, identifies its holder, as has recently been recognized by the National Court, in a ruling dated May 13, 2024 (R 0002336/2021), declaring that "(...) we must start from the premise that the issuance of a duplicate SIM card involves the processing of the personal data of its holder since, according to Article 4.1 of the GDPR, any person whose identity can be determined, directly or indirectly, particularly by means of an identifier, is considered an identifiable natural person. An identifier that constitutes the SIM card, inserted into the mobile terminal, as an intelligent card, in physical format and of small dimensions, which contains a chip in which the service key of the subscriber or user is stored, used for identification before the network, that is, the mobile phone line number of the customer."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
64/120

MSISDN (Mobile Station Integrated Services Digital Network - Mobile Station of the Integrated Services Digital Network), as well as the subscriber's personal identification number IMSI (International Mobile Subscriber Identity - International Mobile Subscriber Identity), and which may also provide other types of data such as information about the telephone directory or call and message logs.

Since 2007, in Spain, in accordance with the Single Additional Provision of Law 25/2007, of October 18, on the retention of data related to electronic communications and public communication networks, it is required that the holders of all SIM cards, whether prepaid or contract, be duly identified and registered. Therefore, when obtaining a duplicate of the SIM card, the person requesting it must also identify themselves, and their identity must match that of the holder.

In this regard, the Judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971: "The concept of 'personal data' used in Article 3, paragraph 1, of Directive 95/46 includes, according to the definition in Article 2, letter a), of that Directive 'any information relating to an identified or identifiable natural person.' This concept undoubtedly includes a person's name along with their phone number or other information related to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must be subject to data protection regulations.

Furthermore, as also indicated in the second section of the response to these allegations, the National Court has also expressed this in several other judgments, such as the judgment of February 8, 2024, and that of February 9, 2023.

For all these reasons, it must be emphasized that the fact that the duplicate of the SIM card was issued by an employee of ORANGE is irrelevant, since, with the issuance of the duplicate card, it acts on behalf of ORANGE, which is responsible for the processing of personal data of its customers. Thus, to the best of this Agency's knowledge, ORANGE has not established appropriate technical or organizational measures to ensure that duplicates of the SIM card are issued only to the holders of the same or to third parties with their authorization.

Fifth: On the correct implementation of privacy by design and by default.

ORANGE expresses its disagreement with the imputation of the infringement of Article 25 of the GDPR in this sanctioning file, and adds that, in the contracting processes and other complementary processes designed by the company, they would have been designed taking into account the privacy and security of the information, including the involvement of the agents themselves.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

65/120

According to ORANGE, the role of these agents is precisely to execute processes by verifying that they are carried out correctly and in accordance with ORANGE's instructions. It adds that the automation of measures to support this work with digital means should be considered as an additional reinforcement for the performance of the functions.

ORANGE goes further by pointing out the existence of a "legitimate possibility for the company to delegate supervisory tasks to designated users, without this being equated to any regulatory non-compliance."

Regarding these allegations, it should be noted, first of all, that Article 25 of the GDPR falls within the general obligations that Chapter IV of the GDPR establishes for the data controller, imposing a design obligation at the moment of determining the means of processing, which must effectively ensure compliance with the principles of data protection.

The GDPR requires controllers to establish the necessary technical and organizational measures throughout the entire lifecycle of the processing, both from the initial moment when the processing is defined and the means are determined, as well as during its implementation and regular operation. Data protection by design aims to apply the principles of data protection in the design processes of the systems and procedures of the organization on which the data processing relies, with a primarily preventive purpose aimed at both avoiding potential harm to individuals and, collaterally, the detriment that modifications or redesigns of the systems in which the processing is carried out could entail for the organization, once developed and implemented, as a consequence of identifying design errors that could cause harm or detriment to the data subjects and their rights and freedoms.

In this regard, Recital 78 of the GDPR states:

The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and apply measures that particularly comply with the

principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
66/120

design these products, services, and applications, and ensure, with due attention to the state of the art, that the controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default must also be taken into account in the context of public contracts.

In particular, in light of Recital 78 of the GDPR, the principle of data protection by design is the key to be followed by the data controller to demonstrate compliance with the GDPR, as the data controller must adopt internal policies and implement measures that specifically comply with the principles of data protection by design and by default.

The principle of privacy by design is a demonstration of the shift from reactivity to proactivity and a direct manifestation of the risk-based approach imposed by the GDPR. As part of proactive responsibility, it requires that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all elements that make up the processing, in order to effectively apply the principles of data protection, integrating the necessary safeguards into the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects.

Thus, regarding the risks that may be present in the processing, the data controller will carry out an exercise of analysis and detection of risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of the data subjects, and not only when the processing actually takes place. This is expressed in the Guidelines 4/2019 of the EDPB regarding Article 25 Data Protection by Design and by Default adopted on October 20, 2020.

In the aforementioned Guidelines, it is indicated that:

“35. The ‘moment of determining the means of processing’ refers to the period of time when the controller is deciding how to carry out the processing and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must assess the appropriate measures and safeguards to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing software and hardware and data processing services.

36. Taking data protection by design into consideration from the outset is crucial for the proper application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to take data protection by design into consideration as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
67/120

Furthermore, the aforementioned Guidelines 4/2019 of the EDPB state that “61. To make the PDDD effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are enshrined in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide from the AEPD asserts that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). The lifecycle of the object refers to all stages it goes through, from conception to withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide states that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Therefore, the measures referred to in Article 25 of the GDPR aim for the company to have the protection of personal data integrated within it, even before the actual processing of personal data begins.

In this way, it is emphasized that the protection of personal data should be taken into account from the very beginning, from the decision-making or planning stage.

ORANGE, in its written submissions regarding the initiation agreement of the present sanctioning procedure, states that it complies with the provisions of Article 25. To this end, it has indicated that it is the office of the Data Protection Officer of the company that intervenes to allow the launch of projects, products, and services that may impact the processing of personal data of ORANGE's customers and users, as reflected in the following documents, which it provides along with its written submissions regarding the initiation agreement of the present sanctioning procedure:

- Document 5 related to the “Privacy Management Dashboard,” which, according to ORANGE, is shared annually with the company.

This document provided by ORANGE is a form in English, referring to the year 2023, in which fields related to the processing of personal data being processed in the company must be completed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

68/120

- Document 6, which is a report containing the opinion of the audit regarding the application of the principles of privacy by design and by default. It is a report from which conclusions are drawn that do not specify any type of action, but rather from ORANGE it is taken into account “the application of the PbDg Principle in order to proactively anticipate events that may affect privacy, avoiding, as much as possible, their materialization and, therefore, the impact on the rights and freedoms of the affected parties in terms of data protection.”

- Document 7, titled “Data Protection Procedure by Design and by Default.” In this document, it is observed that the application of this principle is intended, but it is not materialized in concrete processes; it is only stated that it will be taken into account.

From this documentation, it is concluded that these documents make a generic reference to the possibility of the existence of risks, but they are not identified concretely, and no specific actions are foreseen regarding the possibility of their occurrence. These are not documents from which, after an evaluation of the risks involved in delivering a duplicate SIM card to an unauthorized third party, the application of specific procedures is derived from the beginning of the processing, which contemplate effective concrete measures for their mitigation.

It should not be forgotten that the GDPR aims to achieve the protection of the rights of the data subjects, and therefore, the focus must be directed towards the identification and evaluation of risks to

the rights and freedoms of the data subjects, with the subsequent adoption of technical and organizational measures of all kinds aimed at preventing their materialization.

Thus, if the company's approach is not oriented towards the risks to the rights and freedoms of the data subjects, as is the case here, not only will effective protection for the data subjects not be sought, but it also constitutes a breach of Article 25 of the GDPR.

In its allegations to the initiation agreement of the present sanctioning procedure, ORANGE states that the action that motivated the opening of this sanctioning procedure was caused by the fraudulent action of an agent who caused an error in the system to allow a commercial act by misusing their permissions. ORANGE adds that this fraud was considered to be of low risk.

It also highlights that, when explaining that this process "must not be lost sight of at any moment that ORANGE is a telecommunications company that provides services to its customers, and that they demand agility in the processing and management they request. Delays in these processes are perceived negatively, which requires that the established protocols be compatible with an adequate user experience and, therefore, to have different options to meet the needs of customers."

With this statement, the speed in the customer service process is prioritized over the guarantees of the rights of individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

69/120

ORANGE has also stated that the implementation and supervision of technical security measures is entrusted to the systems department, in the case of fraud detection, although the detection of its possibility is identified by the DPO office or any other area, while the management is coordinated from the specific department of the company specialized in fraud prevention, which evaluates the risks according to a specific protocol and methodology, providing the following documents to substantiate this, which are:

1. Document 8, related to the "Group Risk Management Policy."

This document is provided in English, in which reference is made theoretically to what is considered a risk.

2. Document 9, which contains the Risk Control and Management Policy.

This document is written in Spanish, and in the introduction, it states that it is a model of Risk Control and Management of ORANGE Spain, which is framed within the methodology developed by the ORANGE group, but the document is written theoretically, in such a way that there is no specific mention of the possibility that an employee could (...).

3. Document 10, which describes the functioning of the Local Risk Committee.

4. Document 11, which lists the Internal Control Policy of ORANGE.

From these documents, it is concluded that they refer to the possibility of the existence of risks, but they are not identified specifically, and no specific actions are anticipated regarding the possibility of situations occurring like those that have arisen in the present sanctioning file, in that there is no specific mention of the possibility that an employee could (...).

It should not be forgotten that the GDPR aims to achieve the protection of the rights of the data subjects, and therefore, the focus should be directed towards the identification and assessment of risks to the rights and freedoms of the data subjects, with the subsequent adoption of technical and organizational measures of all kinds aimed at preventing their materialization.

Thus, if the company's approach is not oriented towards the risks to the rights and freedoms of the data subjects, but rather directed towards the risks to the company itself, not only will effective protection for the data subjects not be sought, but it also constitutes a breach of Article 25 of the GDPR.

ORANGE has also expressed its disagreement with the fact that human intervention cannot be carried out in the processes. However, at this point, what is being questioned is that ORANGE had not planned any control for cases where it could (...).

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
70/120

In this way, the response given by ORANGE cannot be considered valid since a fully automated process is not being demanded; rather, the risk was not anticipated in the implementation of the system, as no mechanism was established to prevent the incorrect use of its manual protocols. This is particularly relevant given that the usual procedure for issuing duplicate SIM cards by ORANGE is automated, and it has stated in this very document of allegations that it has suspended the possibility of manual validation of the identity documents of SIM card applicants.

Furthermore, as previously pointed out, it should not be overlooked that ORANGE has stated, when explaining this process, that "it must not be lost sight of at any moment that ORANGE is a telecommunications company that provides services to its customers, and that these demand agility in the processing and management of their requests. Delays in these processes are perceived negatively, which requires that the established protocols be compatible with an adequate user experience and, therefore, to have different options to meet the needs of customers."

For all the above reasons, this allegation by ORANGE cannot be taken into account, as it is not a matter of being unable to automate the procedures, but rather that the agility in the processes does not justify nor can it be an impediment to comply with the provisions of data protection regulations, which are mandatory in cases such as the present, where personal data of the interested parties are being processed.

Sixth: Accumulation of infringements.

ORANGE understands that the initiation agreement refers to a single fact, subject, and basis, which would be the adoption of measures in the procedure for duplicating the SIM card in the specified cases of manual intervention, which would constitute a case of medial concurrence in criminal law or a concurrence of offenses or crimes in administrative law, which applies "as long as the application of one provision prevents or subsumes the applicability of the other," and which makes it contrary to the legal system to sanction the offender twice for the same offense.

ORANGE understands that, from the initiation agreement, it can be inferred that, in relation to the analyzed facts, there is a direct connection between the violations of the two articles.

In this way, the infringement of Article 6.1 of the GDPR, or the existence of an alleged unlawful data processing, was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, derived from the lack of sufficient security measures. Thus, if ORANGE had had measures in place to prevent the duplication of the SIM card, the infringement of the principle of privacy by design and by default under Article 25 of the GDPR could not have been concluded. Consequently, there would be an accumulation of infringements, as the commission of one would necessarily imply the commission of the other.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
71/120

However, in relation to this issue, it must be taken into account that Articles 6.1 and 25 are classified differently in the GDPR, are qualified differently for the purposes of prescription under the LOPDGDD, and each of them has its own entity.

If ORANGE's assertion were true, the violations of these articles would not be classified as different infringements.

Thus, Article 6.1 of the GDPR establishes the circumstances that allow for the lawful processing of personal data.

In this case, ORANGE was accused of issuing a SIM card in the name of the claimant, without the claimant having requested it, and delivering it to an unauthorized third party.

ORANGE has acknowledged this, both in its written submission dated January 30, 2023, and in its written submission dated March 30, 2023, stating that this duplicate was issued on November 15,

2022, without it being requested by the claimant.

Therefore, ORANGE issued a SIM card to a third party who was not the account holder, and did not follow the procedure established by itself, since the duplicate of the card was issued without being requested by the account holder. Ultimately, it carried out these operations of processing personal data without any of the legal bases contemplated in Article 6 of the GDPR being present.

Consequently, the diligence employed by ORANGE in identifying the person requesting the duplicate has been called into question.

In this regard, Recital 40 of the GDPR states:

“(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis established by law, whether in this Regulation or under other Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation to which the controller is subject or the necessity of performing a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.”

On the other hand, in general terms, ORANGE processes its customers' data under the provisions of Article 6.1(b) of the GDPR, when it is considered necessary for the performance of a contract to which the data subject is party or for the application at the request of the data subject of pre-contractual measures. For other cases, the lawfulness of the processing is based on the grounds provided in Article 6.1(a), (c), (e), and (f) of the GDPR.

As previously noted, the processing carried out by ORANGE, in this case, cannot be based on the provisions of paragraph (b) of Article 6.1, since this duplicate SIM card was not based on the performance of any contract, as it was not necessary for its execution nor had it been requested by the claimant; nor was the processing based on any other grounds provided in Article 6.

On the other hand, Article 25 of the GDPR provides:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed by the processing to the rights and freedoms of natural persons, the controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing to meet the requirements of this Regulation and protect the rights of data subjects.

2. The controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation applies to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure in particular that, by default, personal data are not accessible, without the intervention of the data subject, to an indeterminate number of natural persons.

3. An approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate compliance with the obligations laid down in paragraphs 1 and 2 of this Article.”

As can be seen, this article starts from the need to take into account a series of elements:

- State of the art
- Cost of implementation
- Nature, scope, context, and purposes of the processing
- Risks posed by the processing to the rights and freedoms of natural persons.

Furthermore, it imposes an obligation on the controller, who determines the purposes and means of processing, giving special relevance to the means.

And it must apply, both when determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures designed to effectively apply the principles of data protection and integrate the necessary safeguards into the processing.

With this, a dual purpose is pursued:

- To comply with the requirements of the GDPR
- To protect the rights of data subjects.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
73/120

At this point, it is also necessary to take into account the provisions of Recital 78 of the GDPR previously reproduced.

Thus, the measures provided for in Article 25 of the GDPR are not exclusively security measures, but rather it is intended that the company or organization integrates the protection of personal data by design within its organization and ordinary functioning. That is to say, it should be an integral and relevant part of it, even before the actual processing of personal data begins, from the decision-making or planning stage.

The obligation affects the entire organization and involves a continuous process of review and feedback in order to verify whether all existing technical and organizational measures, of all types and implemented by the organization, are adequate to meet the requirements of the GDPR and protect the rights of the data subjects.

In this way, if they are found to be inadequate, they could be modified or, if necessary, reinforced by incorporating new measures that ensure more adequate protection of personal data.

Therefore, in accordance with all of this, it can be appreciated that the perspective or angle through which reality is viewed is different from that provided in Article 6 of the GDPR.

In this sense, the GDPR articulates a complete system aimed at ensuring the protection of the personal data of citizens, and for this purpose, it focuses its attention on various aspects that must be examined by the data controllers or processors.

Each article constitutes an angle from which to observe reality in order to articulate the measures that guarantee adequate protection of personal data, and which must be taken into account to establish protection in accordance with the provisions of the GDPR.

In its written allegations to the initiation agreement, ORANGE states that “the infringement of Article 6.1 GDPR, or the existence of an alleged unlawful data processing was necessary and inevitable for a breach of the principle of privacy by design and by default to occur, derived from the lack of sufficient security measures. Thus, if ORANGE had had measures that allowed for the prevention of SIM card duplication, the infringement of the principle of privacy by design and by default of Article 25 of the GDPR would not have been concluded.”

However, this statement cannot be accepted, as indicated, these are infringements that require the concurrence of different elements for their commission. Thus, on one hand, it is necessary for the commission of the infringement of Article 6 of the GDPR that personal data processing is carried out without having diligently verified that there was a legal basis for it. And on the other hand, the infringement of Article 25 requires the lack or inadequate implementation from the design of appropriate measures to comply with the GDPR, which can occur regardless of whether data processing takes place without a legal basis.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
74/120

Legitimacy. Obviously, both infringements must involve a lack of diligence, but regarding different behaviors.

ORANGE cites the Judgment of the National Court of April 24, 2013, Rec. 69/2011, according to which:

““To assess this infringement, it is essential, in the opinion of the Chamber, to refer to the concurrence of infringements whose existence is also invoked in the complaint. To this end, it is necessary to bring to light the provisions of Article 4.4 of Royal Decree 1398/1993, which states: in the absence of specific regulation established in the corresponding norm, when the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.

This provision has been interpreted by the Supreme Court ruling of February 8, 1999 (Rec. 9/1996) in the sense that the application of concurrent infringements requires a necessary derivation of some infringements with respect to others and vice versa, so it is essential that one cannot be committed without executing the others.”

ORANGE understands that, in the event of an infringement of Articles 6.1 and 25 of the GDPR being appreciated, these would be concurrent infringements, and that the applicable sanction would, in any case, correspond to the breach of Article 6.1 GDPR, taking into account the provisions of Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, which states:

“when the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.”

However, it must be taken into account, in addition to what has been previously stated by this Agency, that, firstly, Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR.

1. The GDPR is a complete system.

The GDPR is a community regulation directly applicable in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation, specifically and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, foreseeing a complete system without gaps that must be understood, interpreted, and integrated in an absolute, complete, and integral manner, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The contrary results in a reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the non-existence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Art. 83.2 of the GDPR) or that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/120

specifies the existing rule regarding a possible joint infringement (art. 83.3 of the GDPR).

In addition to the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of art. 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the aim pursued by the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that,

“(2) The principles and rules relating to the protection of natural persons with regard to the processing of their personal data must, irrespective of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (the emphasis is ours)

Recital 13 of the GDPR further indicates that,

“(13) To ensure a consistent level of protection of natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including microenterprises and small and medium-sized enterprises, and offers natural persons in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent

sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of natural persons with regard to the processing of personal data.” (the emphasis is ours)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in art. 58.2 of the GDPR combined with the provisions of art. 83 of the GDPR show the prevalence of corrective measures over fines.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
76/120

Thus, Article 83.2 of the GDPR states that "Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j)."

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution of them.

All of this aims to enforce compliance with the GDPR, prevent non-compliance, promote adherence, and ensure that the infringement is not more profitable than compliance.

Therefore, Article 83.1 of the GDPR stipulates that "Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive."

Fines must be effective, proportionate, and dissuasive to achieve the intended purpose of the GDPR. For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a different media competition than that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

2. There is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to the above, it should be noted that there is no legal gap regarding the application of media competition. Neither the GDPR allows nor does the LOPDGDD provide for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63, which opens the Title, states that "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, it does not...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
77/120

establishes an absolute subsidiary application regarding the LRJSP which does not contain any provision in its articles related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor subsidiary application of the same, nor is there room for the application of the section related to medial concurrence for the same reasons.

In the specific case examined, and without prejudice to the above, it should be noted that there is no medial concurrence.

Article 29.5 of the LRJSP establishes that “When the commission of an infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.”

Well, medial concurrence occurs when in a specific case the commission of one infringement is a necessary means to commit another distinct one.

The established facts determine, as stated, the commission of two distinct infringements, without the violation of Article 6 of the GDPR (lack of legitimacy in the issuance of the duplicate SIM card of the claimant), as asserted by ORANGE, being the necessary means by which the infringement of Article 25 of the GDPR occurs.

Finally, ORANGE refers to the Guidelines 4/2022 on the calculation of administrative fines under the GDPR, which stipulate the criteria that the administrative authority must follow to evaluate, prior to the imposition of the sanction, the possible concurrence of these.

Regarding the citation of the Guidelines 04/2022 of the EDPB on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 2023, in its section 22, reference is made to three types of concurrences, namely, of infringement, unity of action, and plurality of actions:

“When examining the analysis of the traditions of the Member States regarding concurrency norms, as indicated in the jurisprudence of the CJEU, and taking into account the different fields of application and legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unity of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in this regard is contained in Article 83.3 of the GDPR, which establishes a quantitative limit in these cases of concurrence:

“If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or linked operations, the total amount of the fine...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/120

The administrative penalty shall not exceed the amount provided for the most serious offenses.”
(underline is ours).

If we were to accept the argument put forth by ORANGE, it could be inferred that the “full applicability of the medial concurrence” referred to the preferential application of Article 29 of the LRJSP, in its sole intention to pay a single fine instead of the two imposed, displaces or nullifies the validity of Article 83.3 of the GDPR, which is contrary to the legal system.

Lastly, and no less important, the AEPD does not impose sanctions for the same offense, as ORANGE claims, but rather it has been established through proven facts the commission of two differentiated offenses, classified in a differentiated manner, and there is, moreover, no medial concurrence in the specific case.

For all the above reasons, this allegation is dismissed.

Seventh: On the inadmissibility of objective liability.

In relation to this issue, ORANGE points out that the initiation agreement of the present sanctioning procedure is based on a results analysis, in that it would consider that the issuance of the duplicate SIM card automatically entails the consideration that adequate measures were not taken, thus

automatically arising direct liability on the part of ORANGE, establishing an obligation of result. ORANGE adds that this AEPD limits the obligation to the result, by stating that the failure of ORANGE's agents to meet the measures automatically implies that the measures were insufficient, and that this fact implies adopting a principle of objective liability prohibited by our legal system on numerous occasions by the Constitutional Court.

Conversely, this Agency considers that the deficiencies observed in the measures from the design adopted by ORANGE have been made evident, which demonstrate the non-compliance with Article 25 of the GDPR.

In the present procedure, the existing risk arising from the application known as PSD2 is being analyzed, which is when the type of fraud detailed in the present sanctioning procedure begins to occur, through the use of a duplicate SIM card improperly obtained by a person other than its holder. Thus, the infringement arose not only from the lack of measures for the issuance of duplicate SIM cards but also from the need for their review and reinforcement. This is determined in Article 25 of the GDPR when it states: "...the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures..."

It is not enough to implement technical and organizational measures; they must be adapted and reviewed to mitigate risks. The continuous advancement of technology and the evolution of processing lead to the continuous emergence of new risks that must be managed, as is the case with the SIM swapping attack, used since...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
79/120

For some time now, cybercriminals have been using this method to carry out computer fraud. This is not an operation unknown to ORANGE, whose use should not have surprised them; therefore, when assessing the risks, they should have taken this into account, which translates into a greater use by criminals of mechanisms to obtain duplicates of customers' SIM cards, something that cannot be ignored by ORANGE. In this context, the GDPR requires that data controllers review measures from the design stage, establishing appropriate ones to demonstrate that the rights and freedoms of individuals are guaranteed, taking into account, among others, the "risks of varying probability and severity for the rights and freedoms of natural persons" (Article 24.1) by applying appropriate measures.

In the present case, the technical and organizational measures implemented from the design stage have proven ineffective, as has been established in this sanctioning procedure.

The technical and organizational measures must ensure a level of protection appropriate to the risk, which has not been achieved in this case.

To select the appropriate measures, the controller must base their decisions on the risks to natural persons, as well as on what is reasonable and technically possible. Article 28.2.a) of the LOPDGDD establishes certain scenarios in which it warns that it is necessary to address greater risks than those the controller might estimate if they only considered their own interests (identity theft, economic harm, etc.).

As previously noted in this sanctioning procedure, the SIM card constitutes the physical medium through which access to the personal data of the affected individual is obtained. If its availability and control are not guaranteed, access to the personal data of the holder, as well as the possible use by third parties, becomes a threat that can have devastating effects on the lives of these individuals.

The Constitutional Court stated in its Judgment 94/1998, of May 4, that we are dealing with a fundamental right to data protection, which guarantees individuals control over their data, any personal data, and over its use and destination, to prevent illicit trafficking of the same or harm to the dignity and rights of the affected; thus, the right to data protection is configured as a citizen's ability to oppose the use of certain personal data for purposes other than those that justified its collection.

The risk-based approach and the flexible risk model imposed by the GDPR—starting from the dual

configuration of security as a principle related to processing and an obligation for the controller or processor—does not impose infallibility of the measures in any case, but rather their constant adequacy to a risk that, as in the examined case, is real, probable, and not negligible, high, and with a very significant impact on the rights and freedoms of citizens.

In the instruction of the procedure, it has been established that the technical and organizational measures had not been adapted from the design stage to the risks posed by the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

80/120

technological evolution, which seriously jeopardizes the rights of the interested parties, as the measures were not effective in preventing or mitigating the increased risk of fraud that could arise from requests for duplicate SIM cards, with the aim of perpetrating a SIM swapping attack.

Furthermore, ORANGE cannot deny the fact that it processes personal data on a large scale. Thus, in terms of sanctions, the principle of culpability applies (STC 15/1999, of July 4; 76/1990, of April 26; and 246/1991, of December 19), which means that some form of intent or fault must be present. As stated in the STS of January 23, 1998, "...there can be said to be a decisive line of jurisprudence that rejects objective liability in the administrative sanctioning field, requiring the presence of intent or fault, in line with the interpretation of STC 76/1990, of April 26, which indicates that the principle of culpability can be inferred from the principles of legality and prohibition of excess (Article 25 of the Constitution) or from the inherent requirements of the Rule of Law."

The lack of diligence in implementing appropriate measures at the outset to verify that the person requesting or activating a duplicate SIM card is the holder of that card is, precisely, what constitutes the element of culpability.

Regarding ORANGE being a victim of fraud, it should also be noted that ORANGE must be in a position to establish mechanisms that prevent the fraudulent duplication of SIM cards, measures that respect the integrity and confidentiality of the data and that prevent a third party from accessing data that does not belong to them, as it is precisely the operator's responsibility to process personal data in accordance with the GDPR (recitals 76, 77, 78, 79, 81, and 83 of the GDPR; Article 32 of the GDPR and Article 28 of the LOPDGDD).

Periodic testing, measurement, and evaluation of the effectiveness of the technical and organizational measures applied to the processing are the responsibility of each data controller and processor in accordance with the GDPR.

Therefore, ORANGE, as the data controller, is obliged to verify both the selection and the level of effectiveness of the technical and organizational means used. The thoroughness of this verification must be assessed through the lens of adequacy to risks and proportionality in relation to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of the processing.

Certainly, the principle of responsibility provided for in Article 28 of the LRJSP states: "Only individuals and legal entities, as well as, when a law recognizes them the capacity to act, the groups of affected parties, unions, and entities without legal personality and independent or autonomous estates, that are responsible for the same due to intent or fault, may be sanctioned for acts constituting administrative infractions."

However, the manner of attributing responsibility to legal entities does not correspond to the forms of intentional or negligent culpability that are attributable to human conduct. Thus, in the case of infractions committed by legal entities, although the element of culpability must be present, it is

81/120

necessarily applies in a different manner than it does with natural persons.

According to STC 246/1991 "(...) this distinct construction of the imputability of the authorship of the infringement to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. Capacity for infringement and, therefore, direct reproachability that derives

from the legal good protected by the norm that is infringed and the necessity for that protection to be truly effective and the risk that, consequently, the legal entity that is subject to compliance with that norm must assume" (in this sense, STS of November 24, 2011, Rec 258/2009).

To the above, it should be added, following the judgment of January 23, 1998, partially transcribed in the SSTs of October 9, 2009, Rec 5285/2005, and October 23, 2010, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it must be considered in terms of the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it form part of the proven typical conduct, and that their exclusion requires that the absence of such elements be accredited, or in its normative aspect, that due diligence has been exercised by the one who claims its non-existence; in short, the mere invocation of the absence of fault is not sufficient for exculpation against a typically unlawful behavior."

The ultimate responsibility for the processing remains attributed to the data controller, who determines the existence of the processing and its purpose. Let us remember that operators process their customers' data by determining purposes and means. Therefore, it is the responsibility of the operators (ORANGE, in this case) to implement appropriate measures that ensure compliance with the GDPR, so that if this principle is compromised due to a lack of diligence in implementing sufficient measures for it, the responsibility for such infringement will be attributed to the operator in question.

In this regard, the Judgment of the National Court of February 9, 2023 states:

"The principle of culpability derived from Article 25 CE, as pointed out by STC 246/1991, of December 19, constitutes a basic structural principle of sanctioning administrative law, and is recognized in Article 28.1 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, which provides that:

'Only natural or legal persons (...) who are responsible for them by way of intent or negligence may be sanctioned for acts constituting administrative infringement.'

Therefore, as noted by STS of March 18, 2005, Rec. 7707/2000, it is evident that 'an administrative infringement could not be considered committed if the subjective element of culpability did not concur, or in other words, if the conduct typically constitutive of administrative infringement were not attributable to intent or negligence.'

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

82/120

Regarding the fact that the risks concerning the duplication of SIM cards had not been identified prior to the application of the PSD2 Directive, it should be noted that the contested resolution already indicates - page 872 - "In the present procedure, the existing risk prior to the application of the so-called PSD2 is not being analyzed, but rather the risk that arises from its application, which is when fraud begins to be perpetrated through the use of a duplicate SIM card obtained improperly by a person other than its holder (...) in the present case, the security measures implemented are not sufficient to guarantee the confidentiality of the personal data in question."

Furthermore, it is clear that the risk of identity theft is permanently present in the business activity of (...). It is a real risk aimed ultimately at impersonating another person and seeks, in cases such as the one examined, the contracting of products or the obtaining of a duplicate SIM card by someone who is not the actual holder of it, a risk that the appellant cannot claim was unknown to them.

Regarding the alleged objective liability, the contested resolution does not hold (...) responsible for the outcome, but rather for a loss of confidentiality linked to the insufficiency of the security measures implemented and, ultimately, due to a lack of diligence on the part of that entity.

(...)

This lack of diligence on the part of (...), as the data controller, in implementing adequate security measures to verify that the person requesting or activating the duplicate SIM card is its holder constitutes the element of culpability.

Consequently, the subjective element of culpability necessary for sanctioning is present, incompatible with the existence of the alleged invincible error. The security measures implemented subsequently do not affect the commission of the infringement and, contrary to what the plaintiff intends, cannot justify

the application of an exemption, without prejudice to being taken into account as a mitigating factor under Article 83.2.c) of the GDPR when determining the sanction."

Therefore, the allegation presented by ORANGE cannot be considered.

Eighth: Regarding the measures adopted and implemented by ORANGE.

ORANGE refers to all the measures implemented in relation to the procedure for issuing duplicate SIM cards, both those implemented prior and those implemented subsequently.

In this regard, it refers to:

1. Measures implemented to prevent the commission of fraud arising from identity theft.
 2. Measures implemented by ORANGE to prevent the commission of fraud arising from the impersonation of ORANGE agents and/or employees.
 3. Measures adopted by ORANGE concerning the present case, not included in the previous sections.
- This issue has already been addressed in section five of the response to these allegations, to which we refer.

Ninth: Lack of proportionality of the imposed sanction.

ORANGE makes this assertion stating that it has demonstrated having acted with due diligence in the implementation of measures in the processes of duplicate SIM cards, and that in this case the agents acted individually and maliciously breaking the company's standards and protocols.

In any case, it understands that the sanction included in the initiation agreement is disproportionate considering the circumstances and content of the alleged infringement, which ORANGE denies.

Regarding the breach of the principle of proportionality, the GDPR expressly provides for the possibility of modulation, through the provision of fines that can be adjusted, taking into account a series of effective, proportionate, and deterrent circumstances of each individual case (Article 83.1 and 2 GDPR), general conditions for the imposition of administrative fines that have indeed been analyzed by this Agency, to which the criteria for modulation provided in the LOPDGDD must be added.

It should be noted that the agreed administrative fine will be effective because it will lead the company to apply the technical and organizational measures that guarantee the rights and freedoms of the data subjects, given the critical value of the processing.

It is also proportional to the identified violation, particularly regarding its severity, the circle of affected individuals, and the risks incurred, as well as the financial situation of the company.

Lastly, it is deterrent. A deterrent fine is one that has a genuine deterrent effect. In this regard, the Judgment of the CJEU, of June 13, 2013, Versalis Spa/Commission, C-511/11, ECLI:EU:C:2013:386, states:

"94. Regarding, first of all, the reference to the Showa Denko/Commission judgment, previously cited, it should be noted that Versalis interprets it incorrectly. Indeed, the Court of Justice, by stating in paragraph 23 of that judgment that the deterrent factor is assessed taking into account a multitude of elements and not just the particular situation of the company in question, was referring to points 53 to 55 of the conclusions presented in that case by Advocate General Geelhoed, who essentially indicated that the deterrent multiplier coefficient may aim not only at a 'deterrence...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

84/120

general", defined as an action to disincentivize all companies, in general, from committing the infringement in question, but also a "specific deterrence", consisting of deterring the specific defendant from infringing the rules again in the future. Therefore, the Court of Justice only confirmed, in that judgment, that the Commission was not obliged to limit its assessment to factors related solely to the particular situation of the company in question.

"102. According to established case law, the objective of the deterrent multiplier factor and the consideration, in this context, of the size and overall resources of the company in question lies in the desired impact on the aforementioned company, as the sanction must not be insignificant, especially in relation to the financial capacity of the company (in this sense, see in particular the judgment of June 17, 2010, Lafarge/Commission, C-413/08 P, Rec. p. I-5361, paragraph 104, and the order of February

7, 2012, Total and Elf Aquitaine/Commission, C-421/11 P, paragraph 82)."

The Judgment dated May 11, 2006, issued in the cassation appeal 7133/2003 establishes that: "It must also be taken into account that one of the guiding criteria for the application of this principle of the administrative sanctioning regime (criterion included under the heading of 'principle of proportionality' in paragraph 2 of Article 131 of the aforementioned Law 30/1992) is that the imposition of monetary sanctions should not result in the commission of the classified infringements being more beneficial for the offender than compliance with the infringed rules."

Also important is the case law resulting from the Judgment of the Third Chamber of the Supreme Court, issued on May 27, 2003 (rec. 3725/1999) which states: Proportionality, specifically belonging to the field of sanctions, constitutes one of the principles governing in Administrative Sanctioning Law, and represents a control instrument for the exercise of the sanctioning power by the Administration within, even, the margins that, in principle, the applicable norm indicates for such exercise. It certainly involves a concept that is difficult to determine a priori, but which tends to adjust the sanction, by establishing its specific gradation within the indicated possible margins, to the severity of the constitutive fact of the infringement, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that integrate the factual presumption subject to sanction -and, in particular, as results from Article 131.3 LRJ and PAC, the intentionality or repetition, the nature of the damages caused, and the recidivism-. (SSTS July 19, 1996, February 2, 1998, and December 20, 1999, among many others).

In this case, ORANGE pointed out that it had demonstrated having acted diligently in the processes of duplicate SIM cards, and that, in this case, the agents acted individually and with intent, breaking the company's protocols.

Thus, from this AEPD, it is intended to indicate that, in this case, the actions of the agents are not being examined, but rather the condition,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

85/120

characteristics and appropriateness of the measures adopted by ORANGE, and the actions of the data controller in this regard.

ORANGE wishes to express its disagreement with the interpretation made by this Agency regarding the aggravating factors:

a) the nature, severity, and duration of the infringement (Article 83.2.a) GDPR.

ORANGE states that this aggravating factor is based on the possible commission of fraudulent banking operations, and considers that it is legally unacceptable to use as an argument the use of bank accounts, the monetary damages suffered by the victims of fraud, or the manner in which these operations are carried out by financial entities to justify the imposed sanction, to the extent that "banking entities are the only ones responsible for the security of their operations," as stated by the European Banking Authority in "Opinion on the implementation of the RTS on SCS and CSC" points 37 and 38, where it is determined that the security credentials used to perform secure authentication of payment service users are the responsibility of the account service provider.

In this regard, the Agency considers that the nature of the infringement is very serious since it entails a loss of disposition and control over personal data. It has allowed criminals to steal identities by hijacking the phone number after obtaining a duplicate of the SIM card. Following the entry into force of the PSD2 Directive, as indicated, the mobile phone has taken on a very important role in online payments as it is necessary for transaction confirmation, thus making this device - and by extension the SIM card - a clear target for cybercriminals.

It is worth noting that the PSD2 Directive applies to payment services provided within the Union (Article 2), and not to ORANGE, but it is also true that the issuance of a duplicate SIM card in favor of a third party who is not the line holder provides impersonators with control over the telephone line, and therefore, over the SMS directed to the phone linked to the original SIM card, thus allowing access to the authentication code of the transaction.

It is true that, beforehand, access data to online banking must be known, but it is also necessary to obtain the duplicate of the SIM card belonging to the person to be defrauded in order to obtain the confirmation SMS that the client will receive on their mobile terminal as two-factor authentication, and it is this action (the obtaining of the duplicate) that has been taken into account in the present sanctioning procedure.

Regarding the aggravating factor related to the infringement of Article 25 of the GDPR, ORANGE understands that not all customers should be considered, as not all are natural persons, nor do all request a duplicate of the SIM card. Therefore, it understands that, in this case, there would only be one implicated party, which would be the person who filed the complaint.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
86/120

However, this Agency has already determined that the responsibility attributed to ORANGE is due to its failure to implement adequate technical and organizational measures to ensure data protection for customers from the design stage.

The Agency considers that the level of potential harm is high, as access to duplicates of such SIM cards allows for fraudulent banking operations to be carried out in a short period of time. Through the duplication of SIM cards, the alleged impersonators can gain control of the subscriber's line and thereby receive SMS messages directed to the legitimate subscriber to confirm online transactions by impersonating their identity. These SMS messages are sent by banking entities as part of the two-step verification for operations such as money transfers or online payments, and access to these SMS messages is often the reason for the fraudulent duplication of SIM cards.

It is true that ORANGE is not responsible for the customer identification policies established by banking entities, nor can it be held liable for banking fraud. However, it is also true that if ORANGE ensured the identification and delivery procedure, the verification system of the banking entities could not even be activated. The fraudster, after obtaining the activation of the new SIM, takes control of the telephone line, thus being able to carry out fraudulent banking operations by accessing the SMS messages that banking entities send to their customers. This sequence of events generates a series of serious damages and losses that should have been taken into account in a data protection impact assessment (considering 89, 90, 91 and Article 35 of the GDPR) or in the corresponding risk analysis. Ultimately, from the moment a duplicate is delivered to a person other than the line holder or an authorized person, the customer loses control of the line, and the risks, damages, and losses multiply. Furthermore, the events occur with overwhelming immediacy.

In summary, the application of Article 83.2.a) of the GDPR refers to the severity of the Established Facts, which is evident, among other issues, in the social alarm generated by these fraudulent practices and the very high probability of risk materialization, without the number of claims filed being decisive. This is because what has been analyzed in this sanctioning procedure are the technical and organizational measures implemented by the data controller following the complaint filed with the AEPD.

Regarding ORANGE's statement that not all customers considered in the initiation agreement to determine the number of affected individuals are natural persons, it should be noted that this Agency has taken the data from its website and can provide the number of customers who are natural persons, although, as already mentioned, in applying Article 83.2.a), the number of customers has been taken into account, but also the social alarm generated by these fraudulent practices and the very high probability of risk materialization, without the number of claims filed being decisive.

b) any previous infringement committed by the data controller or processor (Article 83.2.e GDPR)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

ORANGE states that prior infringements that have been committed and sanctioned should not be taken into account, as they are not related to the present case. However, subsection e) of Article 83.2 of the GDPR expressly includes "any previous infringement committed by the controller," so all cases reflected in the initiation agreement would fall under this, considering that it is never indicated that such infringements must be the same as the case in question.

c) the link between the business activity of the defendant and the processing of personal data of clients or third parties (Article 83.2.k GDPR in relation to Article 76.2.b) LOPDGDD.)

ORANGE states that this factor is ambiguous in its assessment for inclusion as an aggravating factor, as such a link does not imply a direct relationship with the alleged infringement, and furthermore, it requires that this aggravating factor be related to the specific factual situation, and therefore that the processing of data does not arise from an intention of the entity, but rather that the commission of a crime takes place.

However, this Agency takes into account that the development of the business activity carried out by ORANGE requires continuous and large-scale processing of personal data of clients, including the issuance of duplicate SIM cards, positioning ORANGE as one of the major telecommunications operators in our country.

Additionally, it should not be forgotten that this specific factual situation arises from a lack of adequate technical and organizational measures on the part of ORANGE.

Finally, it should be added that it is the legislator who foresaw the possibility of using this aggravating factor and that the Agency is limited to applying it.

d) intent or negligence in the infringement.

ORANGE states that this Agency does not relate this aggravating factor, nor does it indicate its application to the present factual situation.

Thus, it understands that, as stated by the CJEU when it indicated that the imposition of coercive sanctions by the administrative authority is only admissible in cases where culpable behavior by the controller or processor is evident, the imposition of this aggravating factor should be reserved for cases where intent or negligence is evident or serious.

Therefore, in this case, where the situation is caused by a criminal act not attributable to ORANGE, it understands that this aggravating factor should not be attributed without any reasoning in this regard. Regarding the fact that the factual situation that has motivated the opening of this sanctioning file is caused by a criminal act not attributable to ORANGE, it reiterates what has already been stated in this proposal for resolution concerning that what is attributed to ORANGE is the fact of not having implemented the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

necessary measures to prevent the duplication of the SIM card in the terms in which it has occurred. In this regard, if ORANGE had been diligent in implementing the appropriate measures for the issuance of duplicate SIM cards, a situation like the one reported by the claimant would not have occurred.

Furthermore, it is considered that ORANGE's conduct corresponds to the infringing type and the title of fault, being deemed to have acted with gross negligence in the violation of Article 25. As a custodian of personal data on a large scale, therefore, accustomed or specifically dedicated to the management of customers' personal data, it must be especially diligent and careful in its handling. That is to say, from the perspective of culpability, we are faced with a correctable error, since, with the application of appropriate technical and organizational measures, these identity thefts could have been avoided.

While the Agency considers that there was no intent on the part of ORANGE, it concludes that it was negligent in failing to ensure a procedure that guaranteed the protection of customers' personal data.

Thus, a socially harmful result occurs that imposes disapproval of the ineffective measures implemented, regardless of the level of commitment demonstrated, which is unquestionable.

Denying the occurrence of negligent conduct by ORANGE would be equivalent to acknowledging that

its behavior—by action or omission—has been diligent. Obviously, we do not share this perspective of the facts, as the lack of due diligence has been established. A large company that processes its customers' personal data on a large scale, systematically and continuously, must exercise extreme care in fulfilling its obligations regarding data protection, as established by jurisprudence.

The SAN of October 17, 2007 (rec. 63/2006) is very illustrative, starting from the premise that these are entities whose activity involves continuous processing of customer data, it indicates that "...the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

In this sense, it is of vital importance to establish and implement the necessary procedures and measures, depending on the characteristics and entity of the operator, that allow demonstrating that due diligence has been exercised in attempting to prevent identity theft from occurring. Furthermore, it must be demonstrable that the necessary precautions have been taken during the course of business activities, as required by regulations, to avoid foreseeable harm. It is a matter of having an objective level of care considering the specific circumstances of the case that makes it evident that one was aware of the possibility of suffering identity theft, and that, consequently, appropriate measures were applied to minimize the realization of such risk to the lowest possible level.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
89/120

On the other hand, ORANGE states that the following mitigating factors should have been taken into account:

- The claimed party proceeded to block the line as soon as it became aware of the facts. (art. 83.2.c). This mitigating factor cannot be considered when, as a consequence of the alleged infringement, the claiming party has suffered losses amounting to 9,000 euros.
- Special categories of data have not been processed (art. 83.2.g).

This allegation cannot be taken into account to the extent that processing personal data included within the category of special data can be considered an aggravating factor for the calculation of the sanction, but processing personal data that is not included within this category can never be considered a mitigating factor when imposing a sanction. Furthermore, it is taken into account that the SIM card is a personal data that has a particularly sensitive nature, as it enables identity theft.

- The degree of cooperation of ORANGE with the AEPD. In this way, ORANGE wishes to state that it has been demonstrated that it has responded in a timely and proper manner to all information requests made, in order to remedy an alleged infringement and mitigate its possible adverse effects (art. 83.2.f). This allegation cannot be taken into account to the extent that responding to information requests sent from this Agency is an obligation of the data controller, as stated in the LOPDGDD.

- Adherence to codes of conduct under Article 40 or certification mechanisms approved under Article 42 (art. 83.2.j).

ORANGE submits as document No. 15 a certificate issued by AENOR, which certifies that ORANGE has had an approved compliance system since September 4, 2023, which meets the requirements of Article 31 bis of the Penal Code, as well as other compliance standards in the area of crime prevention, such as Circular 1/2016, of January 22, from the Attorney General's Office, aimed at mitigating any risk of committing crimes in the context of ORANGE's actions.

This certification cannot be taken into account when determining corrective powers, as it does not concern demonstrating that compliance measures have been adopted in criminal matters, but rather demonstrating that standards in data protection are being met.

- The nonexistent benefit obtained by ORANGE in the processing of the data that is the subject of this sanctioning procedure, adding that, in any case, it would be harmed, as already noted, being a harmed

party in the criminal procedure in which the commission of the crime in question is reported (art. 83.2.k).

This allegation presented by ORANGE cannot be taken into account, to the extent that the fact that no benefits have been obtained cannot be considered a mitigating factor, according to the ruling of the Audiencia Nacional, dated 05/05/2021, rec. 1437/2020, which states: "On the other hand, it must be appreciated as a mitigating factor the non-commission of a prior infringement. Well, Article 83.2 of the GDPR establishes that the circumstance 'e) any prior infringement committed by the controller or the processor' must be taken into account for the imposition of the administrative fine, among others. It is an aggravating circumstance, the fact that the prerequisite for its application does not occur means that it cannot be taken into consideration, but does not imply or allow, as the claimant intends, its application as a mitigating factor"; applied to the case under review, the lack of the prerequisite for its application regarding art. 76.2.c) of the LOPDGDD, that is, obtaining benefits as a consequence of the infringement, does not allow its application as a mitigating factor.

Thus, in accordance with the provisions of Article 83.1 of the GDPR, admitting the absence of benefits as a mitigating factor is not only contrary to the factual prerequisites contemplated in Article 76.2.c), but also contrary to what is established in Article 83.2.k) of the GDPR and the principles indicated. Therefore, valuing the absence of benefits as a mitigating factor would nullify the deterrent effect of the fine, as it diminishes the effect of the circumstances that effectively influence its quantification, providing the controller with a benefit to which it is not entitled. It would be an artificial reduction of the sanction that could lead to the understanding that violating the regulation without obtaining benefits, financial or otherwise, will not produce a negative effect proportional to the seriousness of the infringing act.

In any case, the administrative fines established in the GDPR, in accordance with what is established in its Article 83.2, are imposed based on the circumstances of each individual case and it is not considered that the absence of benefits is an adequate and determining factor for assessing the seriousness of the infringing conduct. Only in the case that this absence of benefits is relevant to determine the degree of unlawfulness and culpability present in the specific infringing action can it be considered as a mitigating factor, in application of Article 83.2.k) of the GDPR, which refers to "any other aggravating or mitigating factor applicable to the circumstances of the case."

IV

Response to the allegations regarding the proposed resolution of the sanctioning procedure

In relation to the allegations made regarding the proposed resolution of this sanctioning procedure, a response is provided according to the order presented by ORANGE:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

91/120

First. On the existence of criminal prejudiciality.

ORANGE insists on its allegation that there would be criminal prejudiciality based on the fact that the individual who committed the infringement was the Agents contracted by the distributor.

It adds that this is particularly relevant because the determination regarding the actions of the agents and the type of crime that is applied to them will condition the potential imputability of responsibility to ORANGE.

Regarding the fact, it states that the coincidence is evident.

And concerning the basis, it states that there is an incompatibility between the imposition of an administrative fine on ORANGE derived from a criminal act of which it is a victim.

It adds that the AEPD intends for ORANGE to respond administratively for a criminal offense committed by Agents of its distributors, merely because the crime is carried out by fraudulently manipulating the operation of its system. In this way, it points out that the distributor is a franchised company, belonging to the distribution channel, external to ORANGE, which acts as the data processor and the illicit act is carried out by the workforce of that franchise, against the documented instructions of my represented party.

ORANGE adds that this AEPD must assume that the conduct of the agents constitutes a criminal offense.

In relation to the statement regarding the existence of criminal prejudiciality, this Agency wishes to state that this issue has already been resolved in the previous foundation by responding to the allegations presented to the initiation agreement, and refers to what is stated in that point, and therefore, the present allegation is dismissed.

On the other hand, ORANGE questions having to respond for the infringement committed by the Agents of its distributors. In this regard, according to the CJEU ruling of December 5, 2023, issued in case C-683/21:

“83- As for the second question regarding whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to processing operations carried out by a processor, it should be recalled that, according to the definition in Article 4, point 8, of the GDPR, a processor is understood to be ‘the natural or legal person, public authority, service, or other body that processes personal data on behalf of the controller.’

84- Since, as indicated in paragraph 36 of this judgment, a data controller is responsible not only for all personal data processing that it carries out itself but also for processing carried out on its behalf, an administrative fine may be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor it has engaged, that has carried out the processing on its behalf.

Furthermore, the SAN ruling of February 8, 2024, rec.0002250/2021 also states:

“Well, it has not been proven that the aforementioned companies, as processors of the acting party, have determined the purposes and means of the processing, nor have they used the customers' data for their own purposes, nor have they interacted with third parties outside the structure and trade name of the appealing company, but rather have acted under the name of the acting party to fulfill its purposes, using its systems to carry out operations with customers.

Therefore, it is not possible to invoke Article 28.10 of the GDPR for a presumed attribution of responsibility to the processors that also implies the exoneration of the data controller, that is, of the company here appealing (...)”

In the present case, as has been established in the Proven Facts, the data processor acted under a franchise regime, with ORANGE providing all “the technical support, know-how, usage licenses for its distinctive signs, and the necessary collaborations to achieve the objectives and purposes of this contract.” Moreover, the processing of personal data was carried out on ORANGE's own information system.

To all this, it must be added that the duplicate SIM card is issued under the ORANGE operator's brand, and the customer contracts with ORANGE, which is the one providing the telecommunications service. Without all this, the duplicate SIM card would have no utility.

Therefore, in accordance with the above, this allegation by ORANGE cannot be taken into account.

Second. On the factual assumption.

2.1. On the consideration of the SIM card as personal data.

ORANGE states that this Agency interprets that the SIM card not only contains but is a personal data in itself.

It also insists that there is no record of any information that could be contained in the SIM card being processed.

It adds that a duplicate SIM card implies the issuance of an empty SIM card, which would not allow access to banking or financial information per se.

Regarding the IMSI, it would be a code contained within the SIM card with a technical purpose, and which is not directly accessible. Furthermore, there is no evidence that this data has been accessed by the Agents in the commission of the crime.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

93/120

In this regard, ORANGE adds that, although it could be considered that this information potentially makes the line holder identifiable, the possibility of identification by third parties other than the operator would require additional information to which they do not have access.

In relation to this issue, it should be noted that, as already stated in the responses to the allegations presented regarding the initiation agreement, in the section "Second: on the factual assumption," the broad interpretation of the concept of personal data has been recognized both in the Judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971, and in numerous judgments of the National Court that are also referenced in those responses, to which reference should be made from here.

There is no doubt that for ORANGE the holder of a SIM card is fully identified and that they are also identified for those who request a duplicate of the SIM card of a specific person's phone number. Therefore, this allegation cannot be taken into account.

2.2. On the execution of banking operations.

ORANGE considers that this Agency uses these associations to aggravate the factual assumption underlying this sanctioning procedure, granting the duplicate SIM card the ability to allow the commission of banking operations, overlooking a prior step where criminals must obtain and use banking credentials to identify themselves and commit identity theft before the financial institution. It insists that this Agency does not analyze the responsibility of the banking entities affected by the identity theft.

Furthermore, ORANGE understands that this Agency is transferring responsibility for a banking operation to ORANGE, qualifying the obligations of operators and those of banking entities as identical.

In its written allegations regarding the proposed resolution, ORANGE provides statements in which it wishes to express its disagreement with the fact that no action has been initiated for banking entities to inform about the functioning of their systems.

It continues by stating that one might ask why banks implemented a reinforced authentication system in 2019 that is considered insecure, in violation of Article 32 of the GDPR, and why information regarding this has not yet been requested.

It insists that this Agency is transferring responsibility for a banking operation to ORANGE, unjustifiably qualifying the obligations as identical. It mentions at this point statements from the European Banking Authority, which would refer to the fact that banking entities are the only ones responsible for the security of their operations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

94/120

It adds that ORANGE cannot be held responsible for the configuration of SMS sending as a second factor of authentication used by the operators of other services such as banking operators. In this regard, it mentions Judgment 142/2024, of March 21, 2024, from the Provincial Court of Oviedo, in which the victim had clicked on a link sent via SMS, resulting in unauthorized access to their customer area, and a transfer of 6,000 euros was made from the bank account, and in which the Provincial Court reiterated the culpability of the banking entity.

This issue, in contrast to what ORANGE has claimed, is indeed extensively addressed in the previous reasoning in response to its allegations regarding the initiation agreement, in the section "Second" also referred to the "factual situation," to which we must refer here, thus rejecting this allegation.

2.3. Regarding the relationship of the authors of the criminal act with ORANGE.

ORANGE states that the agents are employees of a distributor of the ORANGE brand, who holds the role of Data Processor as provided in Article 28 of the GDPR. It adds that it is the data processor who must, when acting on behalf of ORANGE, have the corresponding means to detect and prevent fraudulent actions by its employees. At this point, they refer to labor legislation, stating that, under Article 20, paragraphs 2 and 3 of the Workers' Statute, the power of control lies with the employer of

the employee, and therefore, in this case, it would depend on the distributor of the ORANGE brand. It emphasizes that it cannot be argued that there has been a breach of Article 6 by ORANGE since the fraudulent conduct corresponds to the employees of the processing, who, contrary to the provisions of Article 28 of the GDPR, did not follow the instructions of the data controller, and therefore, the responsibility for the commission of the infringement of Article 6 of the GDPR should fall on the data processor.

Regarding the issue of the data controller and the data processor, ORANGE had already mentioned the possible responsibility of the data processor in section 1 of its allegations to the proposed resolution, and we refer here to what this AEPD indicated at that point.

However, concerning the statements regarding the fact that the agents of the data processor did not follow ORANGE's instructions as the data controller, it is necessary to take into account the Guidelines 7/2020 of the EDPB, which determine that:

“30 Following the line of the fact-based approach, the word ‘determine’ means that the entity that truly exercises decisive influence over the purposes and means of processing is the controller. Generally, the processing contract establishes who is the determining party (the data controller) and who is the party that follows the instructions (the data processor). Even when the data processor offers a service that is previously defined in a specific way, it must present the data controller with a detailed description.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
95/120

of the service, and this must adopt the final decision on the approval of the manner in which the processing will be carried out and request any changes it deems necessary. Furthermore, the processor cannot modify, at a later time, the essential elements of the processing without the approval of the controller.

39. The question is where to draw the line between the decisions reserved for the controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the controller.

40. With respect to the determination of the means, a distinction can be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the controller. These must be mandatorily determined by the controller, although the determination of non-essential means can also be left to them. Essential means are closely linked to the purpose and scope of the processing, such as the type of personal data processed (“What data will be processed?”), the duration of the processing (“How long will the data be processed?”), the categories of recipients (“Who will have access to the data?”), and the categories of data subjects (“To whom do the processed personal data belong?”). In addition to being related to the purpose of the processing, essential means are closely tied to the question of whether the processing is lawful, necessary, and proportionate. Non-essential means relate to more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision on the details of security measures, which can be left to the processor.

41. Although decisions regarding non-essential means can be left to the processor, the controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, all measures required under Article 32 of the GDPR may be mandated. The contract must also establish that the processor will assist the controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the controller remains responsible for implementing appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is compliant with the Regulation (Article 24). To this end, the controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the controller must have complete information about the means used, as this will enable them to make an informed decision in this regard. In order for the controller to demonstrate the legality of the processing, it is advisable to document, in the contract or

another legally binding instrument between the controller and the processor, at least the necessary technical and organizational measures.

(...)

80. Secondly, the processing must be carried out on behalf of a controller, but not under their direct authority or control. Acting "on behalf of"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

96/120

The term "on behalf of" someone means serving the interests of another and refers to the legal concept of "delegation." In the case of data protection regulations, the role of the data processor is to apply the instructions given by the data controller, at least concerning the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the data controller may leave some margin of discretion regarding how to best serve the interests of the controller, allowing the processor to choose the most appropriate technical and organizational means.³²

81. Acting "on behalf of" someone also means that the processor cannot carry out the processing for its own purposes. As stipulated in Article 28, paragraph 10, the data processor will violate the GDPR when it does not adhere to the instructions of the controller and begins to determine its own purposes and means of processing. In such cases, the data processor will be considered responsible for that processing and may be sanctioned for failing to comply with the controller's instructions.

As previously noted, the CJEU ruling states that "a data controller is responsible not only for all processing of personal data that it carries out itself but also for processing carried out on its behalf; an administrative fine may be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor it has engaged, that has carried out the processing on its behalf."

In the present case, as recorded in the Established Facts of this Resolution, the duplication of the SIM card occurs at an ORANGE establishment owned by the company "TOWER PHONE, S.L.," which acts as the data processor for ORANGE.

Reference is also made to the franchise contract between the two entities, dated April 1, 2022, in which it could be verified that:

"II. (...)"

V. (...)

(...).

(...).

"(...).

(...).

(...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

97/120

In addition to this, it should be noted, as previously mentioned, that the customer is, at all times, contracting telephone services with ORANGE, since, in accordance with all that has been stated above and as indicated in the franchise contract, it is ORANGE as the data controller that determines the purpose and means of the processing carried out for the exercise of the activity, and who actually provides the telephone service.

Therefore, based on the above, this allegation by ORANGE should be dismissed.

Third. On the criminal conduct of the agents.

With this allegation, ORANGE is attempting to have this case treated differently from other cases of SIM SWAPPING, given that the case that prompted the opening of this sanctioning procedure would consist of a new variant of criminal conduct.

However, this issue has already been addressed in the allegations to the initiation agreement to which we refer here, in section Third: on ORANGE's role as a victim.

ORANGE states that it had diligent security measures and procedures, and as a consequence, it has been the criminals who have evolved, which would prove that it had an adequate privacy design.

It adds that the emergence of these practices was highlighted in the "Telecom Anti-Fraud Committee" held in March 2023, and that as a consequence of agents being corrupted and being able to engage in criminal activities, a new risk assessment attributed to this threat has been carried out, providing a risk matrix as document No. 1, in which an element related to SIM SWAPPING can be observed, but which is connected to Phishing. And nothing is mentioned regarding fraud by employees.

It also includes as an element "Fraudulent Use of Data by 3rd Parties/ Payment Fraud."

ORANGE states that this matrix can be compared with the one provided as document No. 12 in the allegations to the initiation agreement. This document 12 is titled "2023 Non-Telco Fraud Risk map.

Key risk" and it also includes a section related to "Fraudulent use of Data-3rd Parties" and at this point "(...)"

However, the risk arising from employees potentially using their credentials to commit criminal acts is not included in any of these tables either. The risk referred to as "Fraudulent use of Data-3rd parties" is drafted in a generic manner, and this does not imply that the risk referred to by ORANGE was analyzed and evaluated concerning the measures implemented by ORANGE.

At this point, ORANGE insists that it cannot be interpreted that allowing a store agent to make decisions on certain matters could be equated with a breach of the GDPR, because it contradicts the very regulation contained therein, where it would be considered that the risk lies in the adoption of decisions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

98/120

automated without human intervention. And it added that the purpose of the agent's intervention was to prevent, in specific and defined cases, (...) from denying the interested party access to a contracted service.

ORANGE continues to state that the Agency categorizes the parameterization of (...) as a violation of Article 25.

In relation to this issue, it is necessary to point out that this matter has also been addressed in the proposed resolution, in the sense that ORANGE has implemented a system for the issuance of SIM cards in which if (...), but no longer only, as ORANGE states, when the (...).

(...).

In light of this, ORANGE states that, (...). As ORANGE points out "(...)."

However, as has been demonstrated, (...).

For all the above, this allegation must be rejected.

Fourth. On the non-existence of a lack of standing in the processing of personal data by ORANGE.

With this allegation, ORANGE wants to insist that the facts that led to the opening of the sanctioning file were carried out by employees of one of its data processors, and it understands that this Agency intends to hold ORANGE responsible for the actions of these agents, regardless of whether this conduct may constitute a criminal offense.

However, this issue has already been addressed in the second allegation, section 3 of Foundation III.

It should be noted that what is being judged in this sanctioning procedure regarding the infringement of Article 6 of the GDPR is the fact that the data of the complaining party were processed through the issuance of a duplicate of their SIM card, without any basis for legitimacy being present. To issue the duplicate (...), which demonstrates that ORANGE did not have their consent. The SIM card has been

issued in the name of ORANGE, which means that ORANGE is responsible for the processing and, as such, responsible for ensuring that the processing carried out on its behalf is based on one of the circumstances that legitimize the processing of personal data.

It is ORANGE that must respond for the breach of data protection regulations, without prejudice to any subsequent actions it may take.

Therefore, in light of all the above, this allegation should be rejected.

Fifth. On the correct implementation of privacy by design and by default.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

99/120

ORANGE wishes to state that, based on the statements included in the proposed resolution, privacy by design would indeed have been taken into account, based on the documentation submitted, the design of protocols, and the establishment of measures aimed at ensuring compliance with the principles of data protection.

In this regard, the process for issuing duplicates of SIM cards involves controls and security measures aimed at ensuring that the SIMs are issued at the request of customers and once their identity has been verified, taking into account the protection of the privacy of the interested parties, and believes that this Agency is attempting to disqualify the documentary evidence solely on the premise that a specific offense has occurred.

It adds that ORANGE does have policies aimed at ensuring the application of data protection principles in its business processes, regardless of whether a specific reference to privacy guarantees is identified in each of them, since, while they address the associated risks in this area, this is not the only consideration, just as the analyzed criminal risks or economic or reputational risks are not specified in each of them.

In this sense, as already noted in the proposed resolution, the principle of data protection by design imposes that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment they design and plan a potential processing of personal data, must determine all the elements that make up the processing, in order to effectively apply the principles of data protection, integrating the necessary guarantees into the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the interested parties.

Therefore, from the design of the processing, there were no measures in accordance with Article 25 of the GDPR (...). The absence of measures to ensure that the request for a duplicate card was made by the line holder, coupled with the fact that it was not verified that the delivery was made to the holder, constitutes a breach of the principle of data protection by design.

This means that ORANGE would not have adequately identified and analyzed the risks that (...), nor anticipated or applied from the design the appropriate technical and organizational measures to effectively apply the data protection principles required by Article 25 of the GDPR.

ORANGE merely states that it complied with the stipulated requirements and provides documentation stating that it takes this article into account, but none of them precisely indicates that the principle of data protection by design had been implemented and (...).

To address this issue, it states that the initial documentation it has already provided is the initial information provided for any project in which personal data is processed in order to begin regulating the various activities from a perspective that safeguards privacy and the protection of personal data,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

100/120

and that, for each particular case, the measures deemed appropriate are applied, such as the training

of personnel responsible for the processes. However, it still fails to present such documentation. It states that it submitted document No. 12 in the allegations to the initiation agreement, which, along with document 1 presented in the written allegations to the proposed resolution, would prove that the risk was indeed identified.

However, this Agency understands that these documents do not demonstrate compliance with the principle of data protection by design. The aforementioned document No. 12 referenced is dated 2023 and is titled (...). In the document referred to as 1 of the allegations to the proposed resolution, a risk matrix is provided in which the risk "Fraudulent use of data - 3rd parties" is identified, without further development, and is assessed as a low risk, but it does not indicate whether the risk is to the rights and freedoms of the data subjects or to business continuity.

ORANGE submits as document 2 of its allegations to the proposal the minutes of the Local Risk Committee from 2022 in which the OSP risk management policy and the OSP risk matrix are approved, among other matters, but from its content it seems to imply that the risks to business continuity are evaluated therein. It also submits document No. 3, the residual risk map from the perspective of the rights and freedoms of the data subjects for the year 2022, where the risk of fraud was identified as low, and which, according to ORANGE, was addressed in the Local Risk Committee of 2022, whose minutes were attached as document No. 2.

In this regard, the aforementioned minutes of the Local Risk Committee, dated 10/03/2022, record in section 6. Risks: Integration of Risk Maps:

"(...).

(...).

(...)."

In turn, in section 8 of the minutes: Telco Fraud is recorded:

"(...).

(...).

(...).

(...).

(...).

(...)."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

101/120

In section 9 regarding Non-Telco Fraud, it adds:

"(...)."

As for the risk map submitted as document No. 3, titled 2022 Non-Telco Fraud Risk Map: Fraudulent Use of Data - 3rd Parties, it contains "(...)"

And it states the following:

(...).

Well, according to ORANGE's allegations, this document would have been presented to the Committee whose minutes it has provided as document No. 2, and it would have been discussed therein; however, there is no reference to it in the aforementioned committee minutes.

Furthermore, it must be taken into account that, despite ORANGE's statements, this Agency continues to maintain that the risks to the rights and freedoms derived from (...) have not been foreseen. The internal risk that employees may commit some type of infringement has not been taken into account, but it is also understood that the impact cannot be classified as limited based on the fact that banking entities must refund any charge made due to violations of their systems.

This is evident in the case where the claimant suffered economic losses amounting to 9,000 euros, not to mention that in the complaint filed before the Court that ORANGE has presented in its written allegations to the initiation agreement, there are more individuals who could have been affected, even if they have not filed a complaint with the AEPD. Thus, the impact that this risk has on the rights and

freedoms of individuals is high; therefore, the residual risk cannot be classified as low without the implementation of appropriate measures.

For all these reasons, this Agency has considered that, despite having submitted a document dated 2022, it is understood that this does not allow for the determination of compliance with Article 25 of the GDPR.

Regarding the other issues raised by ORANGE, it should be noted that they have already been addressed in the responses to the allegations to the initiation agreement, section Fifth, so this allegation must be rejected.

Sixth. On the existence of a concurrence of infringements.

ORANGE states that the two infringements are based on the criminal conduct of the agents, which constitutes a case of concurrence of infringements in the administrative pathway.

In this regard, ORANGE understands that what is decisive in determining whether this non-compliance has indeed occurred is the adequacy or otherwise of the measures implemented. It states that, according to the arguments made by this Agency, it would be inferred that there is a direct connection between the violations of both articles. It considers

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

102/120

that the infringement of Article 6 of the GDPR, namely the existence of an (alleged) unlawful data processing, was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, arising from the lack of (as indicated in terms of defense, allegedly) sufficient security measures.

In relation to this allegation, it should be noted that this AEPD reiterates the response given to the allegations regarding the initiation agreement, Section Six.

It is not true that the non-compliance with Article 25 of the GDPR requires data processing without a legal basis. Article 25 imposes an obligation on the controller to adopt the necessary measures to comply with the principle of data protection by design, without it being necessary for the lack of measures or their inadequate implementation to result in any other outcome contrary to the GDPR. It is the non-compliance with the provisions of Article 25 that is sanctioned, which can occur regardless of whether data processing without a legal basis takes place, therefore this allegation should be rejected.

Seventh. On the inadmissibility of objective liability.

ORANGE insists that the proposed resolution is based solely on the outcome, without taking into account that the fact occurred due to the criminal and intentional actions of ORANGE's agents, who acted as data processors, corrupting the process and the measures stipulated by it.

ORANGE understands that the criminal actions of the agents have automatically determined that adequate measures were not adopted, resulting in ORANGE's direct liability arising automatically.

Furthermore, it understands that this Agency has determined that a generic type of fraud has occurred without assessing the specific circumstances of this case.

ORANGE believes that this Agency has erred by considering the following points:

- First, the criminals were commercial agents of a distributor's point of sale, and not cybercriminals.
- Second, this Agency does not take into account the evolution of SIM SWAPPING fraud, considering that, in the event of an alleged fraud, the entity is responsible, regardless of the actions of the point of sale agents.

It insists that they had identified the risk, but it was considered low risk, as it had not occurred previously.

ORANGE considers that, regarding payment services regulations, it would be unjustified to classify the obligations of both operators and banking entities as identical, since ORANGE cannot be held accountable for the deficiencies and decisions made by banks.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

ORANGE states that, according to this Agency, risks must be based on what is reasonable and technically possible, and believes that, in this case, ORANGE had placed its trust in its distributors. It also considers that human intervention is inevitable.

It adds that this Agency expects ORANGE to foresee each and every threat that may occur, anticipating a result in which the measures are infallible, overlooking threats that are difficult to foresee, as would be the case here.

This is why it understands that this Agency establishes an obligation of result, by stating that the commission of a criminal act in ORANGE's environment automatically entails its liability, regardless of the intent employed by the perpetrator, and the level of diligence exercised by ORANGE.

ORANGE states that this Agency has not assessed the jurisprudence presented regarding the inadmissibility of objective liability in the context of the sanctioning administrative procedure.

Therefore, it understands that, since the occurrence of a culpable, intentional, or negligent act by ORANGE has not been proven, it is not appropriate to determine that it has committed an infringement of data protection regulations.

Regarding this allegation, this issue has already been addressed in the response to the allegations regarding the initiation agreement, in Section Seven: on the inadmissibility of objective liability.

Nevertheless, this Agency wishes to express that, contrary to ORANGE's allegations, which insist that this Agency expects ORANGE to foresee each and every threat that may occur, anticipating a result in which the measures are infallible, overlooking threats that are difficult to foresee, as would be the case here, Article 25 of the GDPR states: "...the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures..."

The Guidelines 4/2019 of the European Data Protection Board (EDPB) regarding Article 25 Data protection by design and by default, Version 2.0, Adopted on October 20, 2020, indicate:

"29 The GDPR adopts a coherent risk-based approach in many of its provisions, in Articles 24, 25, 32, and 35, in order to determine the appropriate technical and organizational measures to protect individuals and their personal data and to comply with the requirements of the GDPR. The protected goods are always the same (individuals, through the protection of their personal data), against the same risks (to individuals' rights), and taking into account the same circumstances (the nature, scope, context, and purposes of the processing).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30. When conducting the risk analysis for compliance with Article 25, the data controller must determine the risks associated with a violation of the principles for the rights of the data subjects, as well as their probability and severity, in order to apply measures that effectively mitigate the identified risks. In risk assessments, it is crucial to carry out a systematic and thorough evaluation of the processing. For example, a controller evaluates the specific risks associated with the absence of freely given consent, which constitutes a violation of the principle of lawfulness, in the course of processing personal data of children and young people under 18 years of age as a vulnerable group, in a case where there is no other legal basis, and applies appropriate measures to address and effectively mitigate the identified risks associated with this group of data subjects" (the underlining is ours). In short, compliance with the principle of data protection by design requires identifying the specific risks to the rights and freedoms of individuals that the processing entails, analyzing and evaluating them in such a way as to allow for the effective determination and application from the outset of processing of the specific technical and organizational measures to guarantee each of the data protection principles, such as lawfulness, accuracy, and confidentiality, which in this case has not been done.

As already noted in the response to the allegations regarding the initiation agreement, it is understood that ORANGE, when assessing the risks of using the application it has implemented to issue duplicate SIM cards, did not take into account the risks, as well as their impact on the rights and freedoms of individuals. It has already been demonstrated that the impact this potential risk had on the rights and freedoms of individuals is high, and this was also not taken into account. The lack of diligence in implementing appropriate measures at the outset to verify (...) is precisely what constitutes the element of culpability.

Therefore, this allegation by ORANGE should be rejected.

Eighth. Regarding the measures adopted and implemented by ORANGE.

ORANGE states that it would have already listed the measures it had deployed, both prior to and subsequently, so that this Agency can appreciate the constant evolution and risk analysis, as well as the measures applied, taking into account the evolution of the cases of SIM Swapping fraud.

ORANGE insists that it had established the following measures:

1. Measures implemented by ORANGE to prevent fraud resulting from the identity theft of its customer.

- Documentation already provided that is made available to agents and other personnel capable of carrying out actions at ORANGE.

- Additional communications reiterating the action protocols for issuing duplicate SIM cards.

- (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

105/120

- ORANGE is part of the Spanish Association for Digitalization and participates in the project "Secure Digital Identity," which aims, among other things, to protect against fraud and cyberattacks and to defend data privacy.

- (...).

2. Measures implemented by ORANGE to prevent fraud resulting from the impersonation of agents and/or employees of ORANGE.

- Implementation of a two-factor identification system, which would be in the testing phase with certain users.

- Project (...).

- Traffic control tools, which are used by the ORANGE Risk Analysis Group, and which can generate alerts in case of possible detections of irregular contracts, and which works as follows in the case of duplicate SIM cards:

- (...).

- (...).

3. Measures adopted in relation to the present case, not included in the previous sections.

- The risk associated with this type of case has been modified, having a greater impact on the company's protocols and actions.

- The (...) that occurs in cases like the one that prompted the opening of this sanctioning procedure has been provisionally suspended, in order to determine the appropriate measures to mitigate the identified risks.

In any case, ORANGE wants to express that it carries out constant monitoring and review of the existing risks regarding duplicate SIM cards, that the protocols are updated, and that measures are adopted in accordance with the identified risks, without this allowing for the imposition of a guarantee or requirement of infallibility.

ORANGE states that this Agency has not reviewed this breakdown, and understands that it is necessary to comprehend the threat and to be able to prevent and mitigate its commission, and adds that with this, its willingness to protect the rights of individuals would have been demonstrated, in which the existence of a zero risk is updated and reviewed.

This Agency understands that ORANGE continues to assert that it complies with the provisions of

Article 25 of the GDPR. In this case, it again lists the measures it had implemented, and states that this Agency has not taken them into account.

Some of the measures highlighted by ORANGE are not applicable to cases where the request for SIM cards is made in person. The processing of data not only requires the establishment of cybersecurity measures, but other measures are also necessary to mitigate the risks that arise (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

106/120

ORANGE claims that the possibility of duplicating SIM cards has been eliminated from the customer area and from kiosks; it has been implemented (...); the risk associated with this type of situation has been modified, having a greater impact on the company's protocols and actions, and the (...) that occurs in cases like the one that has led to the opening of this sanctioning procedure has been provisionally suspended, in order to determine the appropriate measures to mitigate the identified risks.

Well, all these measures were not implemented by ORANGE beforehand, but have been applied after the events, so they were not taken into account from the design of the treatment; therefore, they cannot be considered in the present case either.

In the fifth section of the response to the allegations regarding the initiation agreement, it is stated concerning the documents provided by ORANGE:

This is documentation that refers to the possibility of the existence of risks, but does not identify them concretely, and does not foresee specific actions regarding the possibility of situations occurring like the one that has occurred in the present sanctioning file, as there is no specific mention of the possibility that (...).

There is no document that foresees what the risks are (...). It has already been mentioned in the response to these allegations that, from this Agency, it cannot be considered that the possibility of employees being able to duplicate a SIM card can be classified as low, but this would not imply that all employees are potential criminals, only that this possibility must be assessed and measures must be in place regarding it, especially considering the impact on the rights and freedoms of individuals.

ORANGE states that (...).

For all these reasons, it is appropriate to reject the allegation presented by ORANGE.

9. On the lack of proportionality of the proposed sanction.

ORANGE states that it has acted with due diligence in implementing measures in the processes of duplicating SIM cards, but, in the event that this Agency considers that there is such non-compliance, it understands that the sanction is disproportionate, taking into account the circumstances and content of the infringement, to the extent that it has been committed willfully by agents of the distributor.

In this regard, it understands that the following aggravating factors used by this Agency have been applied without the circumstances for their consideration being present:

- Nature, severity, and duration of the infringement (art. 83.2.a) GDPR)

This allegation has already been addressed in the allegations to the initiation agreement of this sanctioning procedure, and therefore, it cannot be taken into account.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

107/120

- Any infringement committed by the controller or processor (art. 83.2.e) GDPR)

ORANGE reiterates its disagreement with the fact that this aggravating factor is used, as the facts that motivated these procedures have nothing to do with the present case.

This allegation has already been addressed in the allegations to the initiation agreement of this sanctioning procedure, and therefore, it cannot be taken into account.

- The link between the business activity of the respondent and the processing of personal data of clients or third parties (art. 83.2.k of the GDPR in relation to article 76.2.b) of the LOPDGDD). This allegation has already been addressed in the allegations to the initiation agreement of this sanctioning procedure, and it should be added that ORANGE's business activity is indeed related to the processing of personal data, as it is obvious that ORANGE's activity necessarily involves carrying out a high number of operations involving the processing of personal data of the individual clients of that entity, which impacts the diligence that must be exercised in complying with the obligations arising from this data processing.

- Intentionality or negligence in the infringement.

This allegation has already been addressed in the allegations to the initiation agreement of this sanctioning procedure.

Regarding the application of this circumstance as an aggravating factor, the National Court has ruled in its SAN of March 1, 2024 (Case Number: 0001757/2021) in which it considers that the application of the circumstance contemplated in article 83.2.b) of the GDPR is appropriate in the case of lack of diligence by entities that carry out large-scale data processing, specifying that "(...) And in this sense, it should be noted that a company like the plaintiff that carries out large-scale, systematic, and continuous personal data processing of its clients must exercise utmost care in complying with its obligations in data protection. The plaintiff emphasizes the absence of intentionality when the provision also speaks of negligence, and it is in that lack of diligence that the contested resolution emphasizes in relation to both infringements (...)"

For this reason, the application of the circumstance contemplated in article 83.2.b) of the GDPR is considered justified.

Furthermore, it considers that this Agency has not taken into account the following mitigating circumstances:

- ORANGE proceeded to block the line when it became aware of the facts. (art. 83.2.c) GDPR)

- Special categories of data have not been processed (art. 83.2.g)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

108/120

- the degree of cooperation of ORANGE with this Agency. (art. 83.2.f)

- adherence to codes of conduct under Article 40 or certification mechanisms approved under Article 42 (art. 83.2.j)

- the nonexistent benefit obtained by ORANGE. (art. 83.2.k), stating that, in any case, it has been harmed.

All these issues have already been addressed in the responses to the allegations regarding the initiation agreement, and they should be rejected.

V

Unfulfilled Obligation

Article 6.1 of the GDPR establishes the circumstances under which the processing of personal data is considered lawful.

"1. Processing shall be lawful only if at least one of the following conditions is met:

a) the data subject has given consent to the processing of their personal data for one or more specific purposes;

b) processing is necessary for the performance of a contract to which the data subject is a party or for the implementation of pre-contractual measures at the request of the data subject;

c) processing is necessary for compliance with a legal obligation to which the data controller is subject;

d) processing is necessary to protect the vital interests of the data subject or of another natural person;

e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) processing is necessary for the purposes of the legitimate interests pursued by the data controller or

by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, particularly when the data subject is a child.

The provisions of point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks.”

In the present case, it is established that a duplicate of the claimant's SIM card has been issued to a third party without their consent, (...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

109/120

Thus, ORANGE acknowledges this fact in its letter dated January 30, 2023, stating: “Having confirmed the irregularity in the request for the duplicate, the Risk Analysis team confirmed that two agents from the ORANGE MADRID ***ADDRESS.1 store acted irregularly, using their credentials from the internal systems of this company to activate the duplicate SIM card.

ORANGE further states that “it was verified that, at the time of contracting, the established protocol was followed by this company by passing an identity document through the identity verification system [...]. This system allows for the identification of valid identity documents. However, despite following the instructions given to the distributors, since it was the agents who acted irregularly, they provided a valid identity document for the duplicate that did not correspond to that of the claimant, which is why, when processed through the system [...], it was identified as correct and the duplication process continued.”

ORANGE has communicated that the procedure to follow when requesting a duplicate of the SIM card is as follows: (...).

(...).

As a general rule, ORANGE adds that (...).

It was this circumstance, in the case at hand, (...).

Therefore, ORANGE provided a duplicate of the claimant's SIM card to a third party, without their consent, (...).

Likewise, (...).

In this regard, Recital 40 of the GDPR states: “(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis laid down by law, whether in this Regulation or under other Union or Member State law to which this Regulation applies, including the necessity of complying with the legal obligation applicable to the data controller or the necessity of performing a contract to which the data subject is a party or for taking steps at the request of the data subject prior to entering into a contract.”

Therefore, in accordance with the evidence available at this stage of the sanctioning procedure, it is considered that the known facts, namely the issuance of a duplicate of the SIM card without the consent of the line holder in this specific case, constitute an infringement attributable to ORANGE for violation of Article 6.1 of the GDPR.

VI

Classification and Qualification of the Infringement

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

110/120

The aforementioned infringement of Article 6.1 of the GDPR constitutes the commission of the infringements typified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a three-year limitation period, in accordance with Article 72.1.b) of the LOPDGDD, which qualifies the following conduct as very serious:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year limitation period, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

VII

Sanction for the infringement of Article 6.1 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damages suffered (paragraph a): the action attributed to ORANGE involves a loss of disposition and control over the personal data of the claimant, which has resulted in identity theft and the execution of fraudulent banking activities. It is important to note that the processing of personal data for the purpose of obtaining a duplicate SIM card can be the gateway to accessing other data that allows for a significant financial loss for its owner, as occurred in this case.

- Any prior infringement committed by the data controller or the processor (paragraph e): it is recorded that, on January 31, 2023, a resolution was issued in procedure no. EXP202204288, in which a fine of 70,000 euros was imposed.

It is recorded that, on January 30, 2023, a resolution was issued in procedure no. EXP202203638, in which a fine of 70,000 euros was also imposed. It is recorded that, on November 10, 2021, a resolution was issued in file PS/00022/2021, in which a fine of 700,000 euros was imposed.

Furthermore, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): the development of the business activity carried out by the entity requires continuous processing of personal data. The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, with respect to the infringement committed by violating what is established in Article 6.1 of the GDPR, allows for the imposition of a sanction of 200,000 € (two hundred thousand euros).

VIII

Data protection by design and by default

Article 25 "Data protection by design and by default" of the GDPR establishes:

"1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect

the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure, in particular, that, by default, personal data are not accessible, without the intervention of the person, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element that certifies compliance with the obligations established in paragraphs 1 and 2 of this Article."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

112/120

This article falls within the general obligations that Chapter IV of the GDPR establishes for the data controller, imposing an obligation to design internal procedures at the time of determining the means of processing and to apply those procedures at the time of processing, in order to effectively ensure compliance with the data protection requirements set forth in the general data protection regulations.

Furthermore, Recital 78 of the GDPR states:

"The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation.

In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that particularly comply with the principles of data protection by design and by default.

Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements.

When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection.

The principles of data protection by design and by default must also be considered in the context of public contracts."

In the present case, it should be noted that ORANGE is the data controller, as it establishes the means and purposes for the processing of personal data.

Thus, for cases of issuing duplicates of SIM cards in-store, ORANGE has communicated that the procedure to follow when requesting a duplicate of the SIM card is (...).

However, ORANGE has informed that (...).

(...).

(...).

The principle of data protection by design imposes that, from the earliest stages of planning a processing activity, this must be considered.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

113/120

First: The data controller, from the moment they design and plan any potential processing of personal data, must determine all the elements that make up the processing, in order to effectively apply the

principles of data protection, integrating the necessary guarantees in the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects. Thus, regarding the risks that may be present in the processing, the data controller shall carry out an analysis and detection exercise of the risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of the data subjects, and not only when the processing actually occurs. This is expressed in the Guidelines 4/2019 of the EDPB regarding Article 25 Data Protection by Design and by Default, adopted on October 20, 2020.

In the aforementioned Guidelines, it is indicated that:

“35. The ‘moment of determining the means of processing’ refers to the period of time when the controller is deciding how to carry out the processing and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must evaluate the appropriate measures and guarantees to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing the software and hardware and data processing services.

36. Considering Data Protection by Design and by Default from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to take Data Protection by Design and by Default into account as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.”

To this end, the data controller must refer to the principles set out in Article 5 of the GDPR when designing the processing, which will serve to assess the effective compliance with the GDPR.

Thus, the aforementioned Guidelines 4/2019 of the EDPB state that:

“61. To make Data Protection by Design and by Default effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive accountability. These principles are set out in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide of the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive accountability approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). By lifecycle

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

114/120

The object encompasses all the stages it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide states that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is not merely an addition that is layered onto a system built in disregard of the GDPR. Linked to the establishment of a true culture of data protection within the organization, it also involves, due to proactive responsibility, the ability to document all decisions made with a “privacy design thinking” approach, demonstrating compliance with the GDPR in this aspect as well.

The risk-based approach refers directly and immediately to a preventive system aimed at visualizing, concerning the processing of personal data, the risks to the rights and freedoms of individuals. In relation to the risks to those rights and freedoms, risks must be identified, their impact assessed, and

the likelihood of their materialization evaluated. Thus, it is not the data that is protected, but the individuals behind it.

The risks to the rights and freedoms of individuals arising from the processing of personal data can vary in severity and likelihood and can cause physical, material, or immaterial harm, tangible or intangible consequences, to the rights and freedoms of individuals. Recital 75 of the GDPR and Article 28.2 of the LOPDGDGDD exemplify some of the risks considered by the legislator, but they are not the only ones. It will depend on the processing and the context in which it is carried out, the purposes, the personal data processed, the individuals involved, the means used, etc.

From the documentation in the file, it has been confirmed that the procedure used by ORANGE for issuing duplicate SIM cards (...).

In the aforementioned Guide on Privacy by Design from the AEPD, various guidelines are established, which are not complied with in the case at hand:

"Any system, process, or infrastructure that is going to use personal data must be conceived and designed from scratch, identifying, a priori, the possible risks to the rights and freedoms of the data subjects and minimizing them so that they do not materialize into harm. A PbD policy is characterized by the adoption of proactive measures that anticipate threats, identifying the weaknesses of the systems to neutralize or minimize risks rather than applying corrective measures to resolve security incidents once they have occurred. That is to say, the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

115/120

PbD moves away from the "remediation policy" and anticipates the materialization of the risk event.

****Privacy by Default:****

"PbD aims to provide the user with the highest level of privacy given the state of the art and, in particular, that personal data is automatically protected in any system, application, product, or service. The default setting must be established from the design at a level that is as respectful as possible in terms of privacy. In the event that the subject does not take any configuration action, their privacy must be guaranteed and remain intact, as it is integrated into the system and configured by default."

****Privacy Embedded in the Design Phase:****

"Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed. To ensure that privacy is taken into account from the early stages of design, the following must be done:

- Consider it a necessary requirement in the lifecycle of systems and services, as well as in the design of the organization's processes.
- Conduct a risk analysis for the rights and freedoms of individuals and, where applicable, impact assessments related to data protection, as an integral part of the design of any new processing initiative.
- Document all decisions made within the organization with a "privacy design thinking" approach.

In this case, it has been established that ORANGE has not implemented measures from the design of the processing to comply with the principles of data protection, such as the principles of lawfulness, accuracy, and confidentiality, in manual processes, as there are no measures to verify that the information entered by the employee is not erroneous and that the request for a duplicate SIM card is made by the line holder.

This implies that it would not have identified and adequately analyzed the risks that a manual process of duplicate SIM cards entails for the rights and freedoms of individuals, nor anticipated or applied from the design the appropriate technical and organizational measures to effectively implement the data protection principles required by Article 25 of the GDPR.

In this regard, it should be noted that according to Article 25 of the GDPR:

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context,

and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of individuals..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
116/120

In the case of natural persons, the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects." That is to say, the protection of the fundamental right to data protection does not consist of a mere "reactive" waiting for a problem that may harm it to arise, but rather the data controllers must design ("data protection by design") in advance of the commencement of processing, the appropriate policies for the protection of that fundamental right. This includes all aspects regulated in the GDPR, starting with the obligations of transparency, respect for the exercise of the rights established in the Regulation, and the establishment of all necessary technical and organizational measures to ensure compliance with said regulation. All of this must be planned and implemented prior to the commencement of processing by the controller.

In this specific case, failing to foresee these measures from the design of the analyzed procedure could determine that ORANGE did not have the appropriate measures in place to prevent a situation like the one that has occurred in this case, (...).

For all the above reasons, it is evident that ORANGE has failed to comply with the obligation to adopt technical and organizational measures from the beginning of the processing that ensure the rights and freedoms of individuals, taking into account the risks involved in this processing, including the risk of impersonation or fraud and financial loss, (...), as has been the case that has led to the opening of this sanctioning file.

Therefore, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to ORANGE, for violation of Article 25 of the GDPR.

IX

Classification of the infringement of Article 25

The aforementioned infringement of Article 25 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
117/120

For the purposes of the limitation period, Article 73 "Serious Offenses" of the LOPDGDD states:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following offenses are considered serious and shall be subject to a limitation period of two years for those that constitute a substantial violation of the articles mentioned therein, particularly the following:

(...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the failure to integrate the necessary safeguards in the processing, as required by Article 25 of Regulation (EU) 2016/679. (...)"

X

Sanction for the violation of Article 25 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the resolution of the sanctioning procedure, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected data subjects and the level of damage and harm they have suffered (paragraph a): At least since the inadequacy of measures to ensure the confidentiality of the data of the data subjects was noted, on November 15, 2022, until the date of the agreement to initiate the present sanctioning procedure, given that there is no record of appropriate measures being adopted since the beginning.

Furthermore, as stated on its website, ORANGE currently has over 21 million customers. In this regard, it should be noted that this is an infringement affecting the procedure for issuing SIM cards, and thus, all ORANGE customers are potentially affected.

Paragraph 54.b.iv of the Guidelines 04/2022 of the EDPB includes, as one of the circumstances to be considered in the scaling of the sanction: "The number of data subjects specifically, but also potentially affected," and clarifies regarding that criterion: "The higher the number of affected data subjects, the greater weight the supervisory authority may attribute to this factor. In many cases, it may also be considered that the infringement assumes 'systematic' connotations and, therefore, may affect, even at different times, additional data subjects who have not lodged complaints or reports with the supervisory authority. The supervisory authority may, depending on the circumstances of the case, consider the relationship between the number of affected data subjects and the total number of data subjects in that context (for example, the number of citizens, customers, or employees) in order to assess whether the infringement is of a systemic nature."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

118/120

- Intentionality/ Negligence in the infringement (section b). In this regard, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not act with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the individual must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it is necessary to emphasize the rigor and exquisite care required to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

- Any previous infringement committed by the responsible party or the data processor (section e): it is recorded that, on January 31, 2023, a resolution was issued in procedure no. EXP202204288, imposing a fine of 70,000 euros. It is recorded that, on January 30, 2023, a resolution was issued in procedure no. EXP202203638, which also imposed a fine of 70,000 euros. It is recorded that, on November 10, 2021, a resolution was issued in file PS/00022/2021, imposing a fine of 700,000 euros. Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of article 76 "Sanctions and corrective measures" of the LOPDGDD:

- Linkage of the infringer's activity with the processing of personal data (section b): the development of the business activity carried out by the entity requires continuous processing of personal data.

The balance of the circumstances contemplated in article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of article 25 of the GDPR, allows for the imposition of an administrative fine of 1,000,000 euros.

XI

Adoption of measures

In accordance with the provisions of the aforementioned article 58.2 d) of the GDPR, according to

which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”, ORANGE is required to notify this Agency within 6 months of the measures it has adopted to ensure that the request for a duplicate is submitted by the holder of the telephone number, regardless of the procedure used for its issuance.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in art. 83.2 of the GDPR.

It is noted that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

119/120

violation in its article 83.5 and 83.6, which may motivate such conduct to open a further sanctioning administrative procedure.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ORANGE ESPAGNE, S.A.U., with NIF A82009812:

- for a violation of article 6 of the GDPR, classified in article 83.5.a) of said regulation, an administrative fine of 200,000 euros (two hundred thousand euros).

- for a violation of article 25 of the GDPR, classified in article 83.4 of said regulation, an administrative fine of 1,000,000 euros (one million euros).

That the Director of the Spanish Agency for Data Protection orders ORANGE ESPAGNE, S.A.U., with NIF A82009812, to notify this Agency, pursuant to article 58.2.d) of the GDPR, within 6 months, the measures it has adopted to ensure that the duplicate request is submitted by the line holder, regardless of the procedure used for its issuance.

SECOND: TO ORDER ORANGE ESPAGNE, S.A.U., with NIF A82009812, to notify this Agency, pursuant to article 58.2.d) of the GDPR, within 6 months, the measures it has adopted to ensure that the duplicate request is submitted by the holder of the phone number, regardless of the procedure used for its issuance.

THIRD: TO NOTIFY this resolution to ORANGE ESPAGNE, S.A.U.

FOURTH: This resolution shall be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that it must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of art. 98.1.b) of the LPACAP, within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, in the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

120/120

In accordance with the provisions of article 76.4 of the LOPDGDD and since the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the violation committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es